



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services



دبلوم امن المعلومات

الفصل 6: تقييم واختبار أمان الأنظمة



دبلوم امن المعلومات

● اسم المقرر:

مبادئ التصميم في الأمن السبراني

● رمز المقرر:

ISE125

● الموضوع:

الفصل 6: تقييم واختبار أمان الأنظمة



يقارن اختبار الصندوق الأسود والأبيض والرمادي من حيث سؤال التصميم.



يميز اختبار الاختراق عن المسح الآلي وعن الاختبار الوظيفي.

يقترح تحسينات تصميم مرتبة حسب الخطورة وارتباطها بنموذج التهديد.



يقيم فجوات امتثال تصميمية مقابل فئات ضوابط دون ادعاء تدقيق رسمي.

يشرح الحدود الأخلاقية والقانونية لاختبار الأمان في المملكة.





خريطة الفصل

ينتقل الفصل من غاية اختبار الأمان والتميز بين أنواعه إلى تحديد النطاق والتصريح وقواعد الاشتباك.

CHAPTER MAP خريطة الفصل



التطبيق الرئيس: بوابة خدمات أكاديمية داخل منشأة سعودية

من الغاية والأنواع إلى النطاق، ثم النتائج والفجوات، ثم قرارات التحسين والاختبار المستمر.



خطة الوحدات الزمنية ونقاط الإكمال



- ▶ يتكون الفصل من خمس وحدات تعلم ذاتي، مدة كل وحدة 60 دقيقة، بإجمالي 300 دقيقة.
- ▶ تتوزع الميزانية على 143 دقيقة للمحتوى والقراءة، و67 دقيقة لأنشطة إلزامية، و50 دقيقة للتقييمات والواجب، و40 دقيقة للمرحلة السادسة من المشروع.
- ▶ يبدأ المتعلم بكل وحدة من دليلها، وينفذ النشاط، ثم التقويم الذاتي، ويسلم جزء الواجب أو المشروع المحدد قبل الانتقال.

الوحدة	المحتوى	النشاط	التقويم والواجب	المشروع	المجموع
الأولى	29	13	10	8	60
الثانية	29	13	10	8	60
الثالثة	29	14	10	7	60
الرابعة	28	14	10	8	60
الخامسة	28	13	10	9	60



خطة الوحدات الزمنية ونقاط الإكمال (تابع)

المدة

60 دقيقة. **الأهداف الخاصة: ** تمييز الاختبار الوظيفي والاختبار الأمني واختبار الاختراق، ومقارنة أساليب الصندوق من حيث المعرفة المتاحة، وتحديد حدود الا

التمهيد

يبدأ المتعلم بفكرة أن نجاح الوظيفة لا يثبت مقاومتها للمخاطر الأمنية.

المحاور

الشرائح 5-12. **النشاط الإلزامي: ** نشاط تصنيف أساليب الاختبار، 13 دقيقة. **التقويم الذاتي: ** 3 دقائق من بنك الأسئلة، الأسئلة 1-3 و6. **مخرج الواجب: **

نقطة الإكمال

حفظ قرار الأسلوب ومبرره في ملف العمل.

المدة

60 دقيقة. **الأهداف الخاصة: ** تحديد عناصر النطاق المكتوب، والتحقق من كفاية التصريح، واتخاذ قرار مهني عند ظهور أثر غير متوقع.

التمهيد

لا يبدأ أي نشاط تقني قبل مطابقة الأصل والبيئة والنشاط مع التفويض المكتوب.



خطة الوحدات الزمنية ونقاط الإكمال (تابع)

المدة

60 دقيقة. **الأهداف الخاصة: ** التمييز بين مؤشرات المسح والنتائج المؤكدة، وتصنيف فجوة التصميم وفجوة التشغيل، وربط النتيجة بقرار تحسين أولي.

التمهيد

لا تعد نتيجة الأداة قراراً علاجياً قبل التحقق من الأصل والسياق والسبب الجذري.

المحاور

الشرائح 18-28. **النشاط الإلزامي: ** نشاط تحليل تقرير النتائج، 14 دقيقة. **التقويم الذاتي: ** 3 دقائق من بنك الأسئلة، الأسئلة 7-9 و15 و18. **مخرج الواجب

نقطة الإكمال

حفظ تصنيف الفجوة والقرار الأولي.

المدة

60 دقيقة. **الأهداف الخاصة: ** حساب درجة الخطر، وتبرير ترتيب المعالجة، وصياغة معيار إعادة اختبار قابل للتحقق.

التمهيد

تدعم درجة الخطر قرار الأولوية، لكنها لا تلغي قراءة الأصل والضوابط وموعد التحقق.



خطة الوحدات الزمنية ونقاط الإكمال (تابع)



- ◀ المدة: 60 دقيقة.
- ◀ الأهداف الخاصة: تقييم حالة ضابط بمصفوفة تعليمية، وصياغة معالجة لاستثناء تشغيلي، وتجميع خطة اختبار مصرح محدودة النطاق.
- ◀ التمهيد: المصفوفة التعليمية توثق الدليل والفجوة والعلاج، ولا تمنح شهادة امتثال رسمية.
- ◀ المحاور: الشرائح 22-25 و31-34 و40-41. النشاط الإلزامي: نشاط تقييم مصفوفة الامتثال، 13 دقيقة.
- ◀ التقويم الذاتي: 3 دقائق من بنك الأسئلة، الأسئلة 13 و14 و24 و25 و29. مخرج الواجب: ينجز المتعلم في سبع دقائق خطة إعادة الاختبار وتحليل إدارة الاستثناءات، ثم يراجع التسليم في ثلاث دقائق.
- ◀ مخرج المشروع: يجمع في تسع دقائق خطة اختبار مصرح ومصفوفة امتثال مبسطة.
- ◀ نقطة الإكمال: تسليم المرحلة السادسة في ملف المشروع.



- ◀ غاية اختبار الأمان هي نشاط منظم للتحقق من خصائص أمنية أو كشف ثغرات أو فحص ضوابط ضمن نطاق معلوم.
- ◀ وظيفته دعم التخطيط والتنفيذ وتحليل النتائج وبناء المعالجة، لا تشغيل أداة بمعزل عن قرار تصميمي.
- ◀ **الوظيفة:** توجيه التقييم إلى غاية محددة.
- ◀ **المسؤوليات:** تحديد الغاية بوضوح، ربطها بالنطاق المكتوب، حماية بيئة الاختبار، تحليل النتائج، اقتراح المعالجة.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، ISO/IEC 27001:2022، ECC-2:2024.
- ◀ **الأجهزة أو الأدوات:** أدوات المسح، الفحص، المراجعة، التحليل.
- ◀ **المخرج:** خطة اختبار، أدلة نتائج، سجل نتائج، توصيات معالجة.
- ◀ **مثال:** تتحقق المنشأة من ضوابط الوصول في بوابة أكاديمية تجريبية قبل الإطلاق.



(الشكل) (Security Testing Purpose) غاية اختبار الأمان



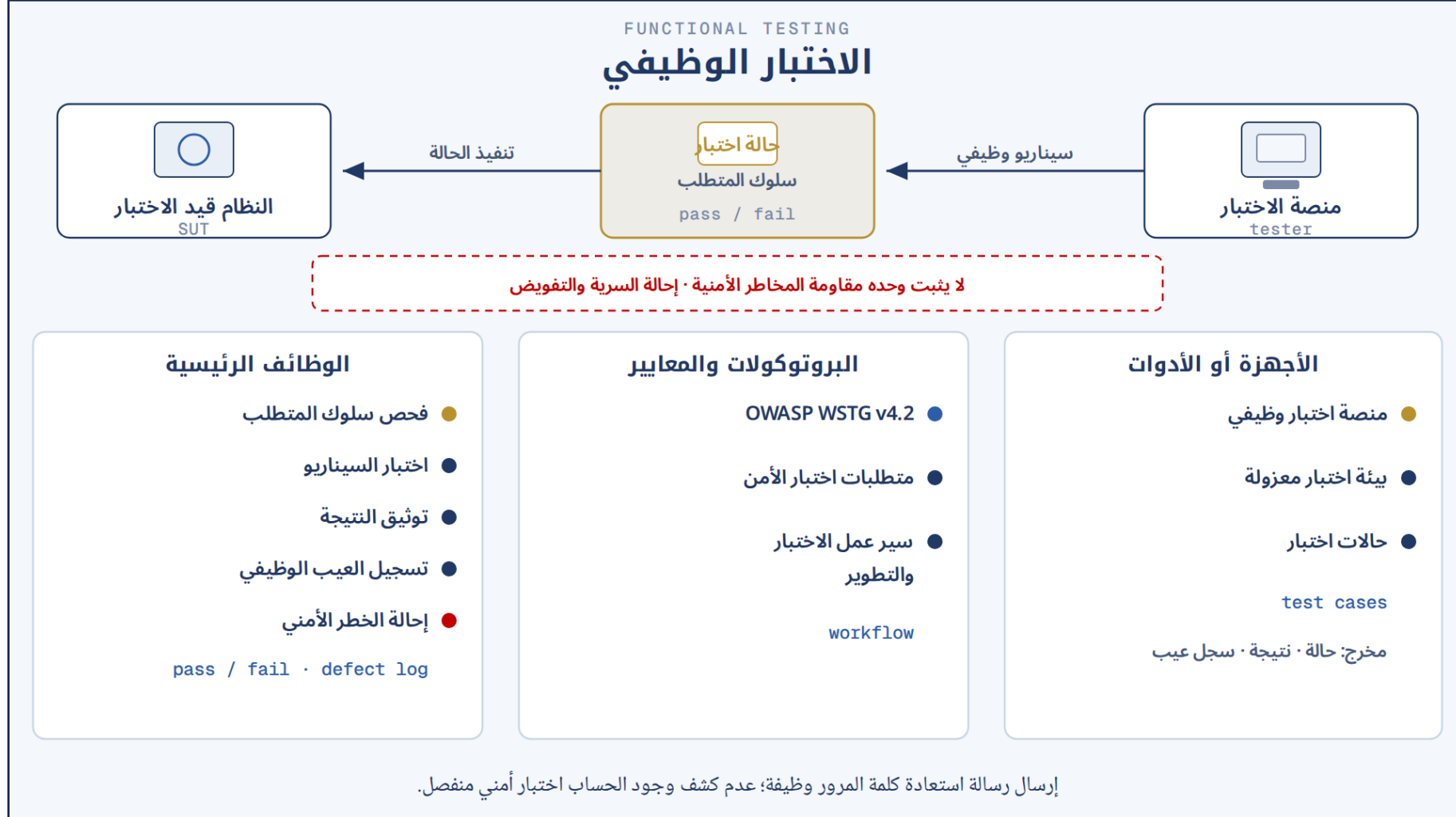


(Functional Testing) الاختبار الوظيفي

- ◀ الاختبار الوظيفي يتحقق من أن الوظيفة تؤدي سلوكها المقصود، لكنه لا يثبت وحده مقاومتها للمخاطر الأمنية.
- ◀ وظيفته إثبات تحقق متطلبات العمل، ثم إحالة الأسئلة المتعلقة بالسرية والتفويض إلى اختبار أمني مخصص.
- ◀ **الوظيفة:** فحص سلوك المتطلب الوظيفي.
- ◀ **المسؤوليات:** اختبار السيناريو الوظيفي، توثيق النتيجة، تسجيل العيب الوظيفي، إحالة الخطر الأمني.
- ◀ **البروتوكولات والمعايير:** OWASP WSTG v4.2، متطلبات اختبار الأمن، سير عمل الاختبار والتطوير.
- ◀ **الأجهزة أو الأدوات:** منصة اختبار وظيفي، بيئة اختبار معزولة، حالات اختبار.
- ◀ **المخرج:** حالة اختبار، نتيجة نجاح أو فشل، سجل عيب وظيفي.
- ◀ **مثال:** إرسال رسالة استعادة كلمة المرور وظيفية، وعدم كشف وجود الحساب اختبار أمني منفصل.



الاختبار الوظيفي (Functional Testing) (الشكل)





الاختبار الأمني (Security Testing)

- ◀ الاختبار الأمني يشمل اختبارات وفحوصاً تقنية تهدف إلى كشف ثغرات أو التحقق من سياسة أو متطلبات محددة.
- ◀ وظيفته ربط الملاحظة بالأصل والضابط والحاجة إلى معالجة، بدلاً من عد التنبيهات فقط.
- ◀ **الوظيفة:** كشف الضعف والتحقق من المتطلبات الأمنية.
- ◀ **المسؤوليات:** التخطيط للتقييم، تنفيذ الفحص المصرح، تحليل النتائج، ربطها بالأصول، التوصية بالمعالجة.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115, OWASP WSTG v4.2, ISO/IEC 27001:2022.
- ◀ **الأجهزة أو الأدوات:** المسح، الفحص، المراجعة، التحليل.
- ◀ **المخرج:** نتيجة موثقة، وصف أثر، توصية معالجة، قرار إعادة اختبار.
- ◀ **مثال:** اختبار ضوابط رفع الملفات في بوابة خدمات بحسابات تجريبية فقط.
- ◀ التعليل: تربط النتيجة بالأصل والضابط لأن التنبيه المجرد لا يحدد قرار المعالجة أو أولوية تنفيذه.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** فحص فريق مصرح لبوابة تجريبية وراجع 6 ملاحظات أولية.
- ◀ ارتبطت 2 بخدمة رفع الملفات، و 3 بالتحكم في الوصول، و 1 بالخادم الوسيط.
- ◀ أكد الفريق ملاحظتين فقط بعد المراجعة اليدوية، إحداها تخص التحكم في الوصول والأخرى تخص رفع الملفات.
- ◀ **الخطوات:**
- 1. نحسب نسبة النتائج المؤكدة: $2 / 6 \times 100 = 33.3\%$.
- 2. نربط النتيجة الأولى بخدمة التحكم في الوصول والضابط المطلوب.
- 3. نربط النتيجة الثانية بواجهة رفع الملفات، ثم نسجل الأثر وقرار المعالجة.



الاختبار الأمني (Security Testing) (تابع)

حالة النتيجة	العدد	قرار التقييم
ملاحظات أولية	6	تحتاج تحليلاً
نتائج مؤكدة	2	تدرج في التقرير
نتائج غير مؤكدة	4	توثق للمراجعة

النتائج: يؤكد التقرير نتيجتين من أصل 6 بنسبة 33.3%، ويعالج الفريق النتائج المؤكدة بدلاً من اعتبار جميع التنبيهات ثغرات ثابتة.

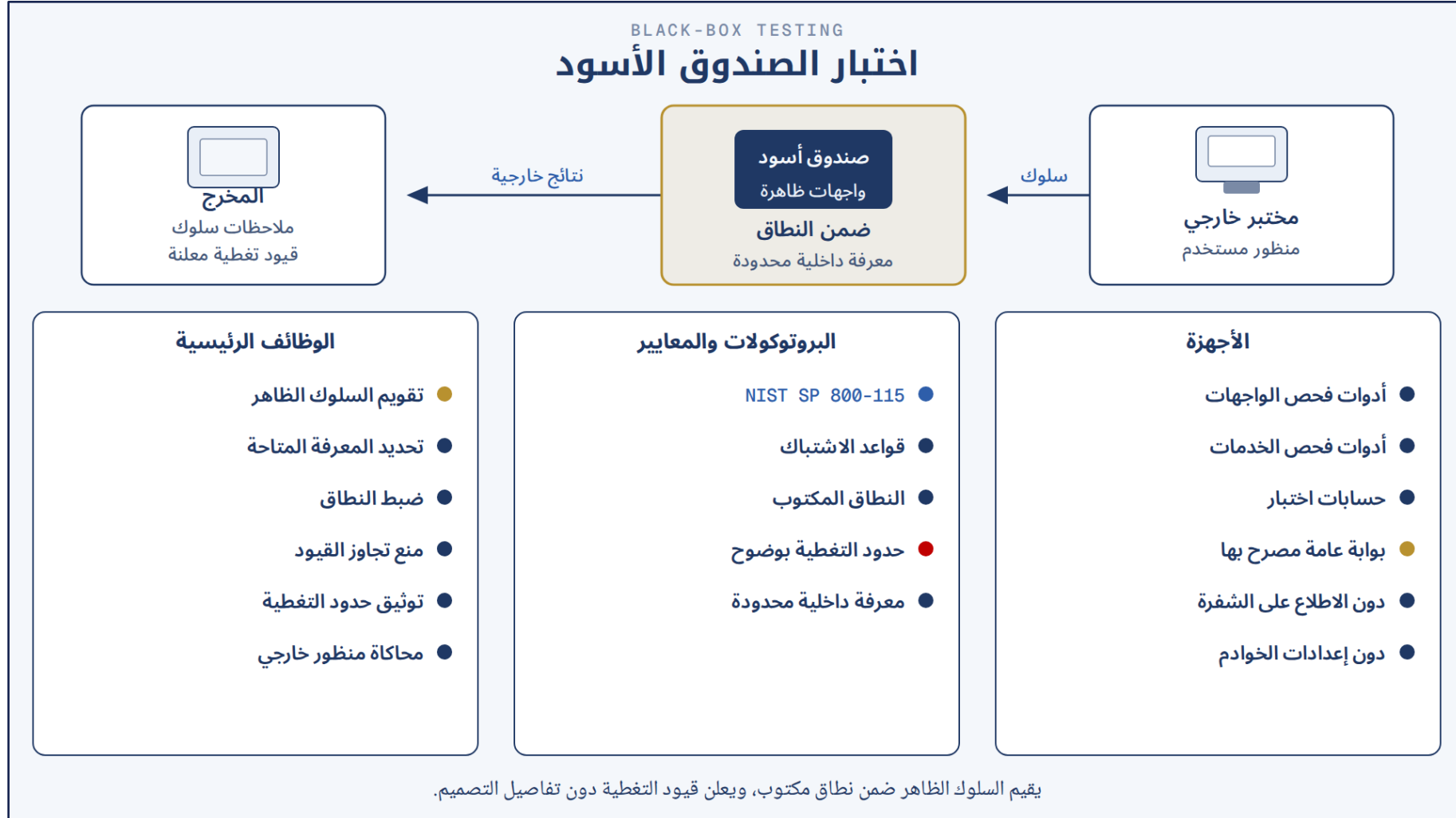


اختبار الصندوق الأسود (Black-Box Testing)

- ◀ اختبار الصندوق الأسود أسلوب يقيم النظام بمعرفة داخلية محدودة، ويركز على السلوك والواجهات الظاهرة ضمن النطاق.
- ◀ وظيفته محاكاة منظور خارجي أو مستخدم لا يملك تفاصيل التصميم، مع توثيق حدود التغطية بوضوح.
- ◀ **الوظيفة:** تقويم السلوك الظاهر للخدمة.
- ◀ **المسؤوليات:** تحديد المعرفة المتاحة، ضبط النطاق، منع تجاوز القيود، توثيق حدود التغطية.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، قواعد الاشتباك، النطاق المكتوب.
- ◀ **الأجهزة أو الأدوات:** أدوات فحص الواجهات، أدوات فحص الخدمات، حسابات اختبار.
- ◀ **المخرج:** ملاحظات سلوك، نتائج خارجية، قيود تغطية معلنة.
- ◀ **مثال:** تفحص بوابة عامة مصرح بها دون الاطلاع على الشفرة أو إعدادات الخوادم.



اختبار الصندوق الأسود (Black-Box Testing) (الشكل)



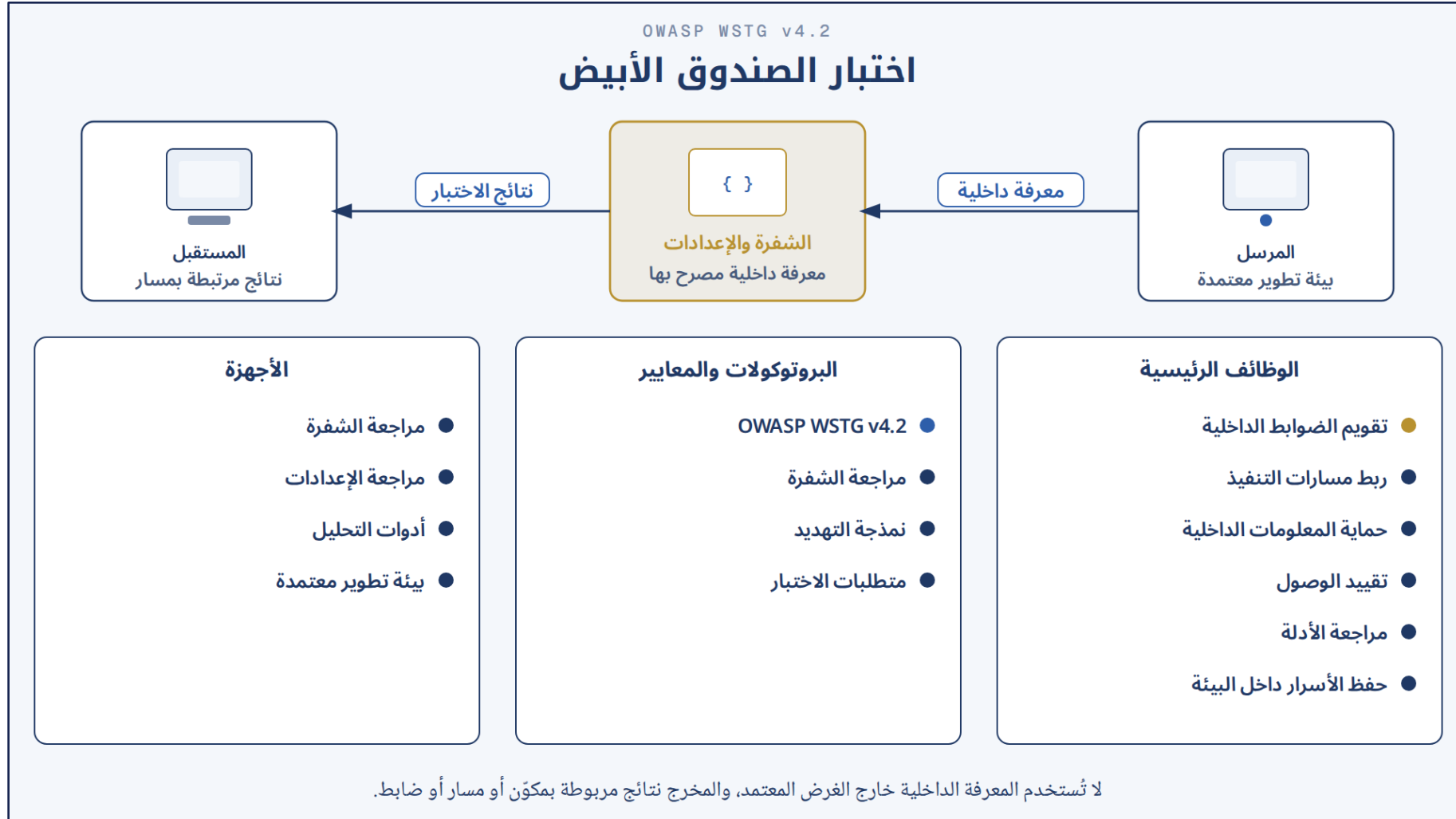


اختبار الصندوق الأبيض (White-Box Testing)

- ◀ اختبار الصندوق الأبيض يستخدم معرفة داخلية مصرحاً بها، مثل التصميم أو الشفرة أو إعدادات بيئة الاختبار، لفحص الضوابط.
- ◀ وظيفته ربط الاختبار بمسارات التنفيذ ومتطلبات التصميم، مع حماية المعلومات الداخلية وعدم استخدامها خارج الغرض المعتمد.
- ◀ **الوظيفة:** تقويم الضوابط الداخلية ومسارات التنفيذ.
- ◀ **المسؤوليات:** حماية المعلومات الداخلية، تقييد الوصول، مراجعة الأدلة، حفظ الأسرار داخل البيئة.
- ◀ **البروتوكولات والمعايير:** OWASP WSTG v4.2، مراجعة الشفرة، نمذجة التهديد، متطلبات الاختبار.
- ◀ **الأجهزة أو الأدوات:** مراجعة الشفرة، مراجعة الإعدادات، أدوات التحليل، بيئة تطوير معتمدة.
- ◀ **المخرج:** نتائج مرتبطة بمكوّن أو مسار أو ضابط.
- ◀ **مثال:** مراجعة منطق التفويض في خدمة موظفين ضمن بيئة تطوير معتمدة.



اختبار الصندوق الأبيض (White-Box Testing) (الشكل)





اختبار الصندوق الرمادي (Gray-Box Testing)

- ◀ اختبار الصندوق الرمادي يوازن بين معرفة جزئية بالنظام ومحاكاة استخدام واقعي.
- ◀ وظيفته توجيه الاختبار إلى مكونات مهمة دون افتراض معرفة كاملة أو انعدام معرفة، لذلك يجب أن يبين التقرير ما أتيح للمختبر وما بقي خارج التغطية.
- ◀ **الوظيفة:** فحص موجّه بمعرفة جزئية.
- ◀ **المسؤوليات:** توثيق المعلومات المتاحة، بيان غير المختبر، حماية المعلومات الداخلية، ضبط حساب الاختبار.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، قواعد الاشتباك، النطاق المكتوب، منهجية الاختبار.
- ◀ **الأجهزة أو الأدوات:** حساب اختبار محدود، وثائق معمارية مختصرة، أدوات فحص مسموحة.
- ◀ **المخرج:** نتائج مرتبطة بمعرفة جزئية وحدودها.
- ◀ **مثال:** يستخدم الفريق حساب طالب تجريبي ومخطط مكونات عام للبوابة.
- ◀ **التعليق:** إعلان المعرفة المتاحة يمنع تفسير التغطية الجزئية على أنها مراجعة كاملة للتصميم الداخلي.



اختبار الصندوق الرمادي (Gray-Box Testing) (تابع)



◀ مثال محلول:

◀ **المعطيات:** يتسلم الفريق حساب طالب تجريبي ومخطط مكونات عام، أي عنصرين معلنين من المعرفة، ويعمل على البوابة التجريبية وواجهات الخدمة الخلفية.

◀ الخطوات:

1. نعد عناصر المعرفة المصرح بها: حساب واحد ومخطط واحد، فيكون المجموع $2 = 1 + 1$.
2. نحدد الأصليين اللذين يوجه إليهما الفحص، وهما البوابة وواجهات الخدمة الخلفية.
3. نسجل ما لم يقدم للفريق، مثل الشفرة وإعدادات الإنتاج، ضمن حدود التقرير.



اختبار الصندوق الرمادي (Gray-Box Testing) (تابع)

فئة المعرفة	العدد	أثرها في الاختبار
حسابات اختبار	1	اختبار السلوك المصرح
مخططات مكونات	1	توجيه الفحص للأصول
مصادر غير متاحة	2	الشفرة وإعدادات الإنتاج خارج التغطية

النتائج: يوضح التقرير أن الفحص استند إلى عنصرين من المعرفة الجزئية، ولا يدعي تغطية الشفرة أو بيئة الإنتاج. التعليل: تحدد المعرفة المعلنة عمق التغطية، لذلك لا يصح تعميم نتيجة حساب تجريبي على الشفرة أو بيئة الإنتاج المستثناة.



اختبار الصندوق الرمادي (Gray-Box Testing) (تابع)



◀ مثال محلول:

◀ **المعطيات:** يملك الفريق حساب طالب تجريبياً واحداً ومخطط مكونات عاماً واحداً.

◀ يشمل النطاق البوابة التجريبية وواجهات الخدمة الخلفية، بينما تبقى الشفرة وإعدادات الإنتاج خارج المعرفة المصرح بها.

◀ الخطوات:

1. نعد مصادر المعرفة المتاحة، وهي $1 + 1 = 2$ مصدرين.
2. نعد الأصول التي توجه إليها المعرفة المتاحة، وهي أصلان.
3. نسجل مصدرين غير متاحين، هما الشفرة وإعدادات الإنتاج، ضمن قيد التغطية.



اختبار الصندوق الرمادي (Gray-Box Testing) (تابع)

فئة المراجعة	العدد	أثرها
مصادر معرفة متاحة	2	توجيه الاختبار
أصول موجهة	2	البوابة والواجهات
مصادر غير متاحة	2	تقيد الاستنتاج

النتائج: ينفذ الفريق اختبار الصندوق الرمادي على أصليين بمعرفتين معلنتين، ويذكر صراحة أن مصدرين داخليين خارج التغطية.



مقارنة أساليب الاختبار وسؤال التصميم

أسلوب الاختبار	المعرفة المسبقة	سؤال التصميم الأساسي	الميزة الرئيسية	القيد الرئيس
الصندوق الأسود	محدودة	كيف يظهر السلوك للخارج؟	يحاكي منظوراً خارجياً	لا يكشف كل التفاصيل الداخلية
الصندوق الرمادي	جزئية	كيف تؤثر المعرفة المحدودة في الفحص؟	يوجه الجهد لمكونات مهمة	يعتمد على دقة المعلومات المتاحة
الصندوق الأبيض	مصرح بها داخلياً	هل تعمل الضوابط في المسارات الداخلية؟	يربط النتيجة بالتصميم	يتطلب حماية معلومات داخلية



نشاط إلزامي، تصنيف أساليب الاختبار



- ◀ الزمن: 13 دقيقة.
- ◀ تعمل المنشأة على بوابة تجريبية مصرح بها.
- ◀ الحالة الأولى لا تتيح سوى الواجهة العامة.
- ◀ الحالة الثانية تتيح حساب طالب تجريبي ومخطط مكونات عام.
- ◀ الحالة الثالثة تتيح مراجعة الشفرة وإعدادات بيئة الاختبار.
- ◀ صنف كل حالة إلى صندوق أسود أو رمادي أو أبيض، ثم اكتب سطرين يبينان حد التغطية في كل حالة.
- ◀ **النتائج المطلوبة:** جدول من ثلاثة صفوف يتضمن الحالة والأسلوب وحد التغطية.
- ◀ لا تستخدم أي بيانات إنتاجية أو معلومات غير واردة في التفويض.



إجابة النشاط، تصنيف أساليب الاختبار

- ◀ الحالة الأولى اختبار صندوق أسود لأن المعرفة تقتصر على الواجهة العامة، ولا تثبت النتيجة سلامة المسارات الداخلية.
- ◀ الحالة الثانية اختبار صندوق رمادي لأن حساب الطالب والمخطط يقدمان معرفة جزئية معلنة.
- ◀ الحالة الثالثة اختبار صندوق أبيض لأن الشفرة والإعدادات متاحة بموجب تصريح.
- ◀ يذكر التقرير دائماً المعرفة المتاحة وما بقي خارج التغطية.

الحالة	الأسلوب	حد التغطية
واجهة عامة فقط	الصندوق الأسود	المسارات الداخلية غير مفحوصة
حساب ومخطط عام	الصندوق الرمادي	المعرفة جزئية
شفرة وإعدادات مصرح بها	الصندوق الأبيض	يقتصر على البيئة المصرح بها

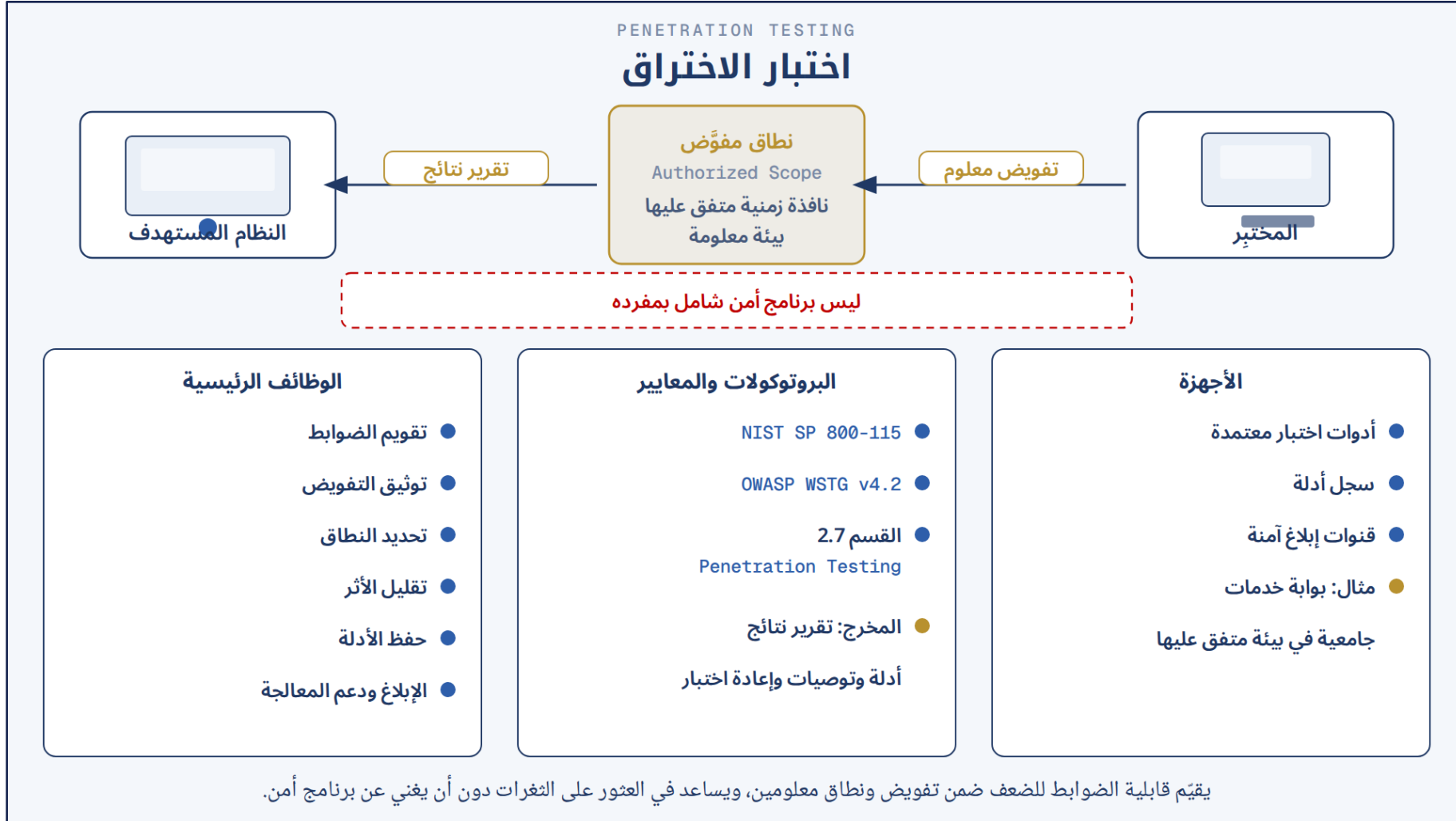


اختبار الاختراق (Penetration Testing)

- ◀ اختبار الاختراق نوع من الاختبار الأمني يقيّم قابلية الضوابط أو النظام للتعرض للضعف ضمن تفويض ونطاق معلومين.
- ◀ وظيفته المساعدة في العثور على الثغرات أو تقويم الضوابط، ولا يمثل برنامج أمن شامل بمفرده.
- ◀ **الوظيفة:** تقويم الضوابط ضمن تفويض محدد.
- ◀ **المسؤوليات:** توثيق التفويض، تحديد النطاق، تقليل الأثر، حفظ الأدلة، الإبلاغ، دعم المعالجة.
- ▶ **البروتوكولات والمعايير:** NIST SP 800-115, OWASP WSTG v4.2, 2.7, Penetration Testing القسم 2.7.
- ◀ **الأجهزة أو الأدوات:** أدوات اختبار معتمدة، سجل أدلة، قنوات إبلاغ آمنة.
- ◀ **المخرج:** تقرير نتائج، أدلة مصرح بها، توصيات، طلب إعادة اختبار.
- ◀ **مثال:** اختبار بوابة خدمات جامعية في نافذة زمنية وبيئة متفق عليهما.



اختبار الاختراق (Penetration Testing) (الشكل)





قواعد الاشتباك (Rules of Engagement)

- ◀ قواعد الاشتباك وثيقة تضبط ما يجوز وما لا يجوز أثناء التقييم، ومن يصرح، ومتى يتم العمل، وكيف يرفع التصعيد.
- ◀ وظيفتها تقليل المخاطر التشغيلية والقانونية والأخلاقية للاختبار قبل بدايته.
- ◀ **الوظيفة:** ضبط النشاط المصرح وحماية الخدمة.
- ◀ **المسؤوليات:** تحديد الأصول، تحديد جهات الاتصال، ضبط نافذة العمل، وضع إجراءات الإيقاف، حماية الأدلة.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، خطة التقييم، نظام مكافحة جرائم المعلوماتية.
- ◀ **الأجهزة أو الأدوات:** قائمة أدوات مسموحة، سجل أصول، قناة تصعيد، وثيقة قواعد اشتباك.
- ◀ **المخرج:** وثيقة معتمدة أو ملحق لخطة الاختبار.
- ◀ **مثال:** يمنع التقييم المؤثر في خدمة دفع حية ويقصر العمل على بيانات اختبار اصطناعية.
- ◀ التعليل: تحدد قاعدة الإيقاف الإجراء الواجب عند ظهور أثر غير متوقع، فلا يترك القرار لاجتهاد المختبر أثناء الخدمة.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** نافذة اختبار البوابة من 2026-03-22 الساعة 20:15 إلى 2026-03-24 الساعة 23:35، وفي الوثيقة أربعة أنشطة مسموحة وستة أنشطة محظورة.
- ◀ **الخطوات:**
- 1. نحسب مدة النافذة: 48 ساعة + 3 ساعات و 20 دقيقة = 51 ساعة و 20 دقيقة.
- 2. نتحقق من أن فحص مسارات المصادقة ضمن الأنشطة الأربعة المسموحة.
- 3. نستبعد الوصول إلى بيانات حقيقية لأنه واحد من الأنشطة الستة المحظورة.



قواعد الاشتباك (Rules of Engagement) (تابع)

نوع القرار	العدد	مثال من الوثيقة
أنشطة مسموحة	4	توثيق النتائج
أنشطة محظورة	6	حجب الخدمة
مدة العمل	51 ساعة و20 دقيقة	خارج أوقات الذروة

النتائج: يقتصر التقييم على الأنشطة المسموحة خلال 51 ساعة و20 دقيقة، ويوقف فوراً إذا ظهر أثر على التوافر أو سلامة البيانات. التعليق: تمنع آلية الإيقاف استمرار النشاط عند ظهور أثر تشغيلي، فتقدم حماية التوافر وسلامة البيانات على استكمال الفحص.



قواعد الاشتباك (Rules of Engagement) (تابع)



◀ مثال محلول:

◀ **المعطيات:** تتضمن الوثيقة 4 أنشطة مسموحة و6 أنشطة محظورة.

◀ أثناء نافذة الاختبار ظهرت استجابة غير متوقعة بعد نشاط تحقق من مسار مصادقة مصرح به، ولم يجمع الفريق بيانات شخصية حقيقية.

◀ الخطوات:

1. نتحقق من أن النشاط من الأنشطة الأربعة المسموحة.
2. نطبق قاعدة الإيقاف فور ظهور أثر غير متوقع، فلا يستمر الفريق في الفحص.
3. نوثق أن الأنشطة المحظورة تمثل $60\% = 100 \times 10 / 6$ من إجمالي الأنشطة المحددة.



قواعد الاشتباك (Rules of Engagement) (تابع)

عنصر القرار	القيمة	الإجراء
أنشطة مسموحة	4	تنفذ ضمن النافذة
أنشطة محظورة	6	لا تنفذ
أثر غير متوقع	1	إيقاف وتصعيد

النتائج: يوقف الفريق النشاط ويبلغ نقطة الاتصال عبر القناة الآمنة، ولا يحول وجود نشاط مصرح به إلى إذن بالاستمرار بعد ظهور أثر غير متوقع.



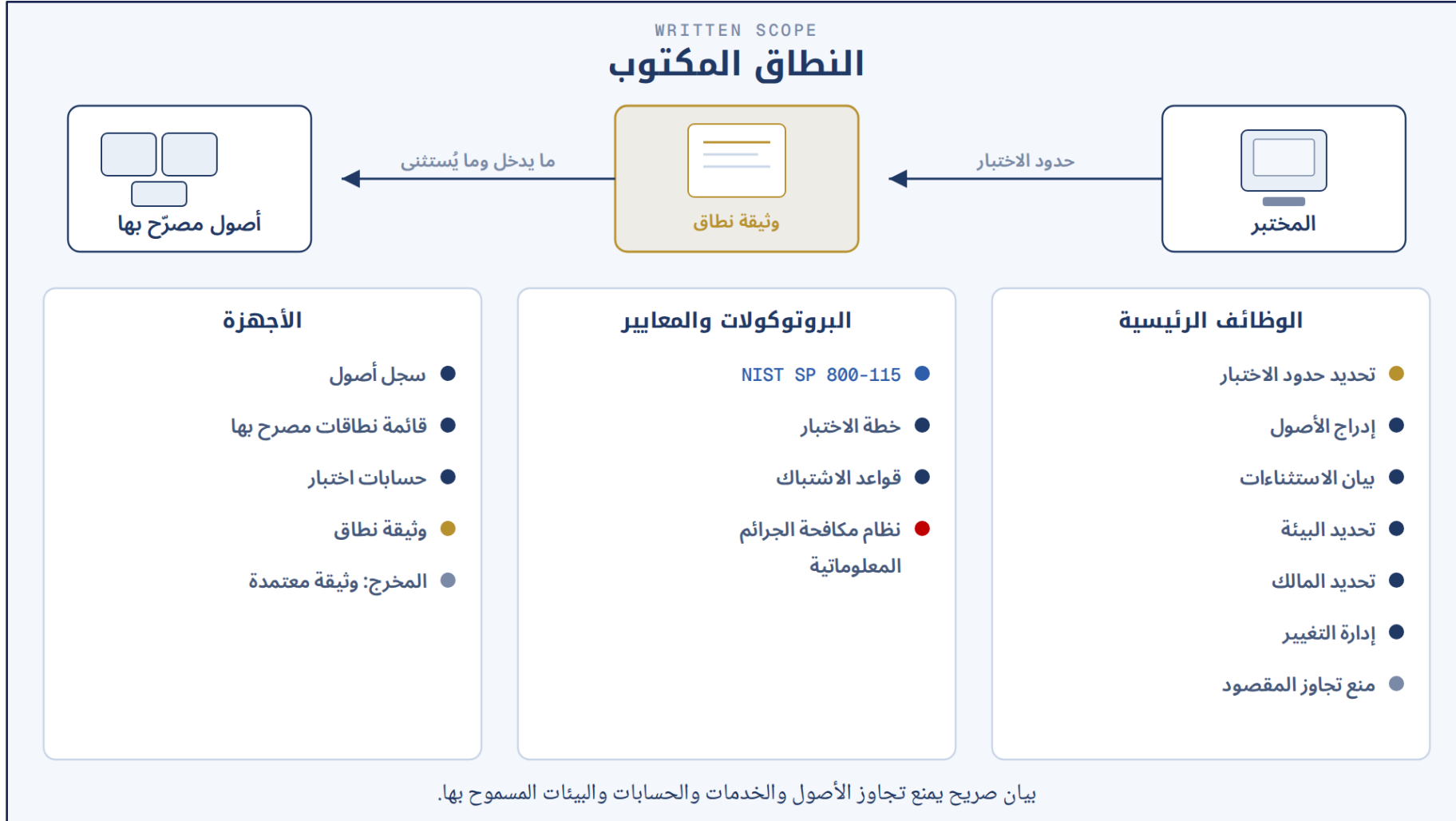
- ◀ اقرأ تاريخ اعتماد الخطة في 2026-03-12، ثم حدد غاية التقييم المتعلقة بالهوية والتحكم في الوصول وحماية البيانات.
- ◀ راجع الأصول الداخلة في النطاق، وهي البوابة التجريبية وواجهات الخدمة الخلفية وحسابات الاختبار.
- ◀ لاحظ أن بيئة الإنتاج وأنظمة الدفع مستثناة صراحة، ولذلك لا يشملها الاختبار.



- ◀ النطاق المكتوب بيان صريح للأصول والخدمات والحسابات والبيئات والوقت والأنشطة المسموح بها في الاختبار.
- ◀ وظيفته منع تجاوز النظام أو البيانات المقصودة بالتقييم، وإظهار ما يدخل في العمل وما يستثنى منه.
- ◀ **الوظيفة:** تحديد حدود الاختبار القابلة للمراجعة.
- ◀ **المسؤوليات:** إدراج الأصول، بيان الاستثناءات، تحديد البيئة، تحديد المالك، إدارة التغيير.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، خطة الاختبار، قواعد الاشتباك، نظام مكافحة جرائم المعلوماتية.
- ◀ **الأجهزة أو الأدوات:** سجل أصول، قائمة نطاقات مصرح بها، حسابات اختبار، وثيقة نطاق.
- ◀ **المخرج:** وثيقة نطاق معتمدة.
- ◀ **مثال:** تستثنى الوثيقة البريد المؤسسي والموردين الخارجيين وكل نطاق غير وارد في الموافقة.



النطاق المكتوب (Written Scope) (الشكل)





(Legal Authorization) التصريح القانوني

- ◀ التصريح القانوني تفويض رسمي من مالك مخول يبيح نشاط الاختبار في نطاق محدد.
- ◀ وظيفته بيان مشروعية الإجراء داخل حدود التفويض وتقليل الالتباس بشأن الوصول أو التعديل غير المصرح به.
- ◀ **الوظيفة:** تثبيت مشروعية النشاط وحدوده.
- ◀ **المسؤوليات:** التحقق من جهة التفويض، حفظ التفويض، الالتزام بشروطه، إيقاف العمل عند تغير النطاق.
- ◀ **البروتوكولات والمعايير:** نظام مكافحة جرائم المعلوماتية، المرسوم الملكي م/17، NIST SP 800-115.
- ◀ **الأجهزة أو الأدوات:** خطاب تفويض، عقد، أمر عمل، موافقة معتمدة.
- ◀ **المخرج:** تفويض مكتوب قابل للمراجعة.
- ◀ **مثال:** يحدد التكليف المكتوب بوابة تجريبية وبيئة اختبار وفترة تنفيذ واضحة.
- ◀ التعليل: لا يغطي التفويض أصلاً جديداً أو نشاطاً جديداً ما لم يرد صراحة في الموافقة الخطية المعتمدة.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** تشمل الموافقة ثلاثة أصول، هي البوابة التجريبية وواجهات الخدمة الخلفية وحسابات الاختبار.
- ◀ وتستثنى ستة أصول أو فئات، منها بيئة الإنتاج وأنظمة الدفع.
- ◀ **الخطوات:**
- 1. نعد الأصول الداخلة في النطاق، وعددها 3.
- 2. نعد الاستثناءات الصريحة، وعددها 6.
- 3. نحسب عناصر قرار النطاق: $9 = 6 + 3$ عناصر يجب أن تظهر في التفويض.



التصريح القانوني (Legal Authorization) (تابع)

حالة الأصل	العدد	قرار الاختبار
داخل النطاق	3	يجوز الاختبار وفق الموافقة
مستثنى صراحة	6	يمنع الاختبار
عناصر قرار النطاق	9	توثق في التفويض

النتائج: لا يبدأ الفريق العمل إلا بعد مطابقة الأصول الثلاثة مع التفويض، ويطلب تفويضاً خطياً جديداً لأي أصل من الاستثناءات الستة. التعليل: يثبت التفويض المكتوب حدود النشاط، لذلك لا تمتد الموافقة إلى أصل مستثنى أو خدمة لم تسمها الوثيقة.

◀ مثال محلول:

- ◀ **المعطيات:** يراجع الفريق طلب فحص يتضمن 4 أصول: البوابة التجريبية، واجهات الخدمة الخلفية، حسابات الاختبار، والبريد الإلكتروني المؤسسي.
- ◀ تسمى وثيقة التفويض الأصول الثلاثة الأولى فقط، وتستثني البريد الإلكتروني المؤسسي صراحة.

◀ الخطوات:

1. نطابق كل أصل مع قائمة التفويض المكتوبة.
2. نجد أن 3 أصول من أصل 4 مصرح بها.
3. نحسب نسبة الأصول المصرح بها: $3 / 4 \times 100 = 75\%$.



التصريح القانوني (Legal Authorization) (تابع)

الأصل	حالة التفويض	قرار الفريق
البوابة التجريبية	مصرح	يجوز الاختبار
واجهات الخدمة الخلفية	مصرح	يجوز الاختبار
حسابات الاختبار	مصرح	يجوز الاختبار
البريد المؤسسي	مستثنى	يطلب تفويض جديد

النتائج: يعمل الفريق على 75% من الأصول المقترحة فقط، ويستبعد البريد المؤسسي حتى يصدر تفويض خطي جديد.



(Ethical Responsibility) المسؤولية الأخلاقية

- ◀ المسؤولية الأخلاقية تلزم المختبر بالحد الأدنى الضروري من الإجراء، وحماية البيانات، وعدم تجاوز التفويض، والإبلاغ المسؤول.
- ◀ وظيفتها حماية الأفراد والجهة والنظام من ضرر غير لازم أثناء التقييم.
- ◀ **الوظيفة:** تقليل الضرر وحماية السرية.
- ◀ **المسؤوليات:** عدم استخراج بيانات غير لازمة، عدم تعطيل الخدمة، حفظ الأدلة، الإبلاغ المسؤول، احترام السرية.
- ◀ **البروتوكولات والمعايير:** قواعد الاشتباك، NIST SP 800-115، نظام مكافحة جرائم المعلوماتية، سياسات الجهة.
- ◀ **الأجهزة أو الأدوات:** سجل قرارات، أدلة مخفضة الحساسية، إشعار تصعيد، تقرير مسؤول.
- ◀ **المخرج:** تقرير يحمي البيانات ويبين القيود.
- ◀ **مثال:** يثبت الفريق إمكان الوصول بسجل تجريبي بدلاً من نسخ سجلات طلاب حقيقية.
- ◀ التعليل: إثبات الملاحظة بحساب اختبار يحقق غرض التقييم ويقلل تعرض البيانات الشخصية غير اللازمة.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** تسمح الوثيقة بحسابات اختبار منشأة مسبقاً ببيانات غير حقيقية، وتحظر الوصول إلى بيانات حقيقية وتغيير سجلات الإنتاج.
- ◀ **الخطوات:**
- 1. تختار حساب اختبار واحداً لإثبات نتيجة التفويض.
- 2. تحدد كمية البيانات الشخصية الحقيقية المطلوب جمعها، وهي 0.
- 3. نحفظ دليلاً مخفض الحساسية ونبلغ عبر القناة الآمنة عند ظهور أثر غير متوقع.



المسؤولية الأخلاقية (Ethical Responsibility) (تابع)

عنصر الدليل	الكمية	القرار الأخلاقي
حسابات اختبار مستخدمة	1	مسموح
بيانات شخصية حقيقية مجمعة	0	ممنوع جمعها
سجلات إنتاج معدلة	0	ممنوع تغييرها

النتائج: يوثق الفريق النتيجة بحساب اختبار واحد، مع صفر بيانات شخصية حقيقية وصفر تعديلات على سجلات الإنتاج. التعليل: يحقق الدليل المخفض الحساسية غاية التقييم مع تقليل تعرض البيانات الشخصية وتجنب تعديل سجلات الإنتاج.



المسؤولية الأخلاقية (Ethical Responsibility) (تابع)



◀ مثال محلول:

◀ **المعطيات:** يحتاج الفريق إلى إثبات نتيجة مرتبطة بالتفويض.

◀ لديه حسابا اختبار ببيانات غير حقيقية، ويمنع التفويض الوصول إلى بيانات حقيقية أو تغيير سجلات الإنتاج.

◀ استخدم الفريق حساباً واحداً وسجل دليلاً واحداً مخفض الحساسية.

◀ الخطوات:

1. نختار حساب اختبار واحداً من أصل حسابين متاحين.
2. نحدد البيانات الشخصية الحقيقية المجمعة، وهي 0.
3. نحدد سجلات الإنتاج المعدلة، وهي 0، ثم نحفظ الدليل في القناة الآمنة.



المسؤولية الأخلاقية (Ethical Responsibility) (تابع)

عنصر الممارسة	العدد	الحكم الأخلاقي
حسابات اختبار متاحة	2	مسموحة
حسابات مستخدمة	1	كافية للإثبات
بيانات حقيقية مجمعة	0	ممنوعة
سجلات إنتاج معدلة	0	ممنوعة

النتائج: يثبت الفريق الملاحظة بدليل واحد وحساب اختبار واحد، من دون جمع بيانات حقيقية أو إجراء تعديل على الإنتاج.



نشاط إلزامي، قراءة قواعد الاشتباك



- ◀ الزمن: 13 دقيقة.
- ◀ اقرأ وثيقة قواعد الاشتباك.
- ◀ أنشئ جدولاً من عمودين يصنف بوابة الخدمات الأكاديمية التجريبية، وواجهات الخدمة الخلفية المخصصة للاختبار، وحسابات الاختبار، وبيئة الإنتاج، وأنظمة الدفع، والبريد الإلكتروني المؤسسي.
- ◀ أضف سبب القرار، ثم اكتب الإجراء الذي تتخذه عند ظهور أثر غير متوقع على التوافر أو تكامل البيانات.
- ◀ **النتائج المطلوب:** ستة قرارات نطاق وإجراء إيقاف وتصعيد واحد، في ملف العمل.



إجابة النشاط، قراءة قواعد الاشتباك

- ◀ تدخل البوابة التجريبية والواجهات الخلفية المخصصة للاختبار وحسابات الاختبار في النطاق لأنها مسماة في التفويض.
- ◀ تستثنى بيئة الإنتاج وأنظمة الدفع والبريد الإلكتروني المؤسسي صراحة.
- ◀ عند ظهور أثر غير متوقع، يوقف الفريق النشاط فوراً ويبلغ نقطة الاتصال المعتمدة عبر القناة الآمنة.
- ◀ لا يوسع النطاق ولا يجمع بيانات شخصية حقيقية.

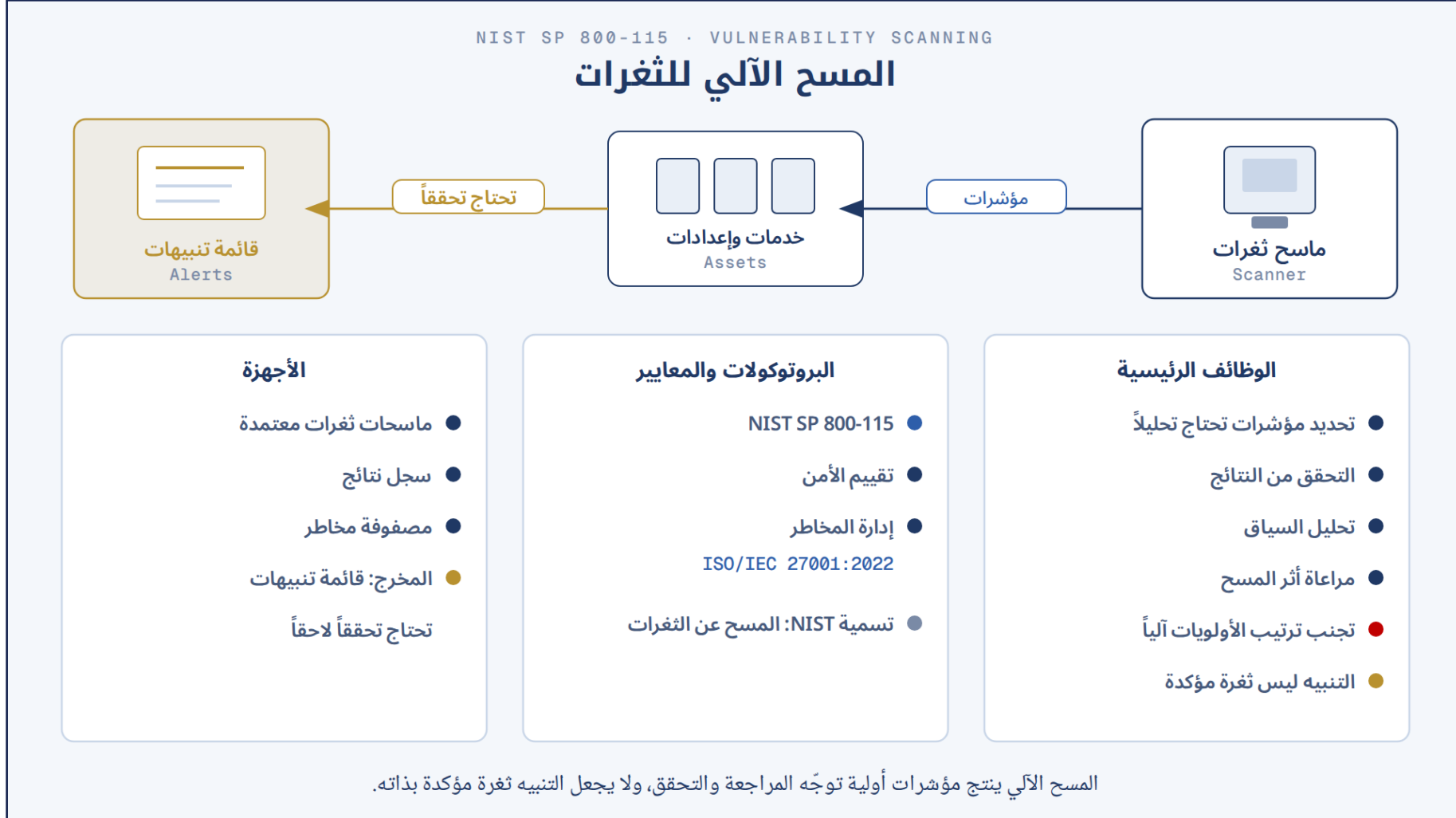
العنصر	القرار
البوابة والواجهات وحسابات الاختبار	داخل النطاق
بيئة الإنتاج وأنظمة الدفع والبريد المؤسسي	مستثناة
أثر غير متوقع	إيقاف فوري وتصعيد آمن

(Vulnerability Scanning) المسح الآلي للثغرات

- ◀ المسح الآلي للثغرات استخدام آلي لفحص مؤشرات ثغرات أو إعدادات أو خدمات، وتسميه NIST المسح عن الثغرات.
- ◀ وظيفته إنتاج مؤشرات أولية توجه المراجعة والتحقق اللاحق، ولا تجعل التنبيه ثغرة مؤكدة بذاته.
- ◀ **الوظيفة:** تحديد مؤشرات تحتاج تحليلاً.
- ◀ **المسؤوليات:** التحقق من النتائج، تحليل السياق، مراعاة أثر المسح، تجنب ترتيب الأولويات آلياً.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، تقييم الأمن، إدارة المخاطر وفق ISO/IEC 27001:2022.
- ◀ **الأجهزة أو الأدوات:** مساحات ثغرات معتمدة، سجل نتائج، مصفوفة مخاطر.
- ◀ **المخرج:** قائمة تنبيهات تحتاج تحققاً.
- ◀ **مثال:** يفحص الفريق بيئة تجريبية ثم يربط كل نتيجة بالأصل والضابط قبل ترتيبها.



المسح الآلي للثغرات (Vulnerability Scanning) (الشكل)





- ◀ الاختبار اليدوي مراجعة أو فحص يعتمد على حكم المختبر وتحليل السياق، وتذكر OWASP الفحوص والمراجعات اليدوية صراحة.
- ◀ وظيفته تقويم منطق التصميم ومسارات العمل والضوابط التي لا يكفي كشفها آلياً.
- ◀ **الوظيفة:** تحليل منطق النظام والسياق.
- ◀ **المسؤوليات:** اتباع قائمة تحقق، توثيق الملاحظة، تجنب التخمين، حماية الأدلة، ربط النتيجة بالأثر.
- ▶ **المعايير:** OWASP WSTG v4.2, Manual Inspections and Reviews, Threat Modeling, Source Code Review.
- ◀ **الأجهزة أو الأدوات:** قوائم تحقق، وثائق تصميم، حالات اختبار، مخرجات مراجعة.
- ◀ **المخرج:** ملاحظة مراجعة ودليل وتوصية.
- ◀ **مثال:** يراجع الفريق ما إذا كانت رسالة الاستعادة تكشف وجود حساب مستخدم.



الاختبار اليدوي (Manual Testing) (الشكل)

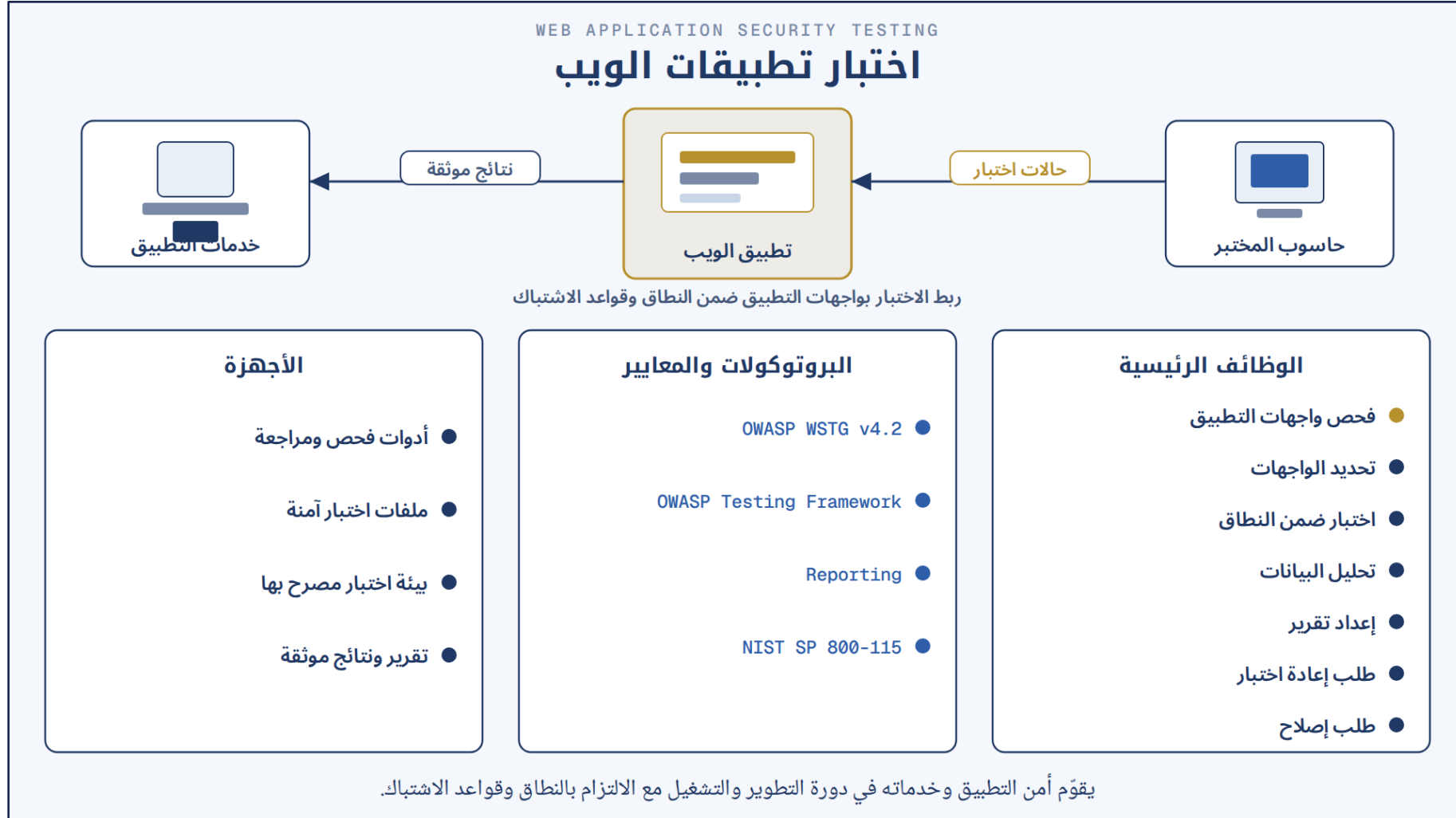




- ◀ اختبار تطبيقات الويب يقوم أمن التطبيق وخدماته ضمن دورة التطوير والتشغيل.
- ◀ وظيفته ربط الاختبار بواجهات التطبيق ومتطلبات الاختبار والتحليل والإبلاغ، مع الالتزام بالنطاق وقواعد الاشتباك.
- ◀ **الوظيفة:** فحص واجهات التطبيق وخدماته بأمان.
- ◀ **المسؤوليات:** تحديد الواجهات، اختبار ضمن النطاق، تحليل البيانات، إعداد تقرير، طلب إعادة اختبار.
- ▶ **المعايير:** OWASP WSTG v4.2, OWASP Testing Framework, Reporting, NIST SP 800-115.
- ◀ **الأجهزة أو الأدوات:** أدوات فحص ومراجعة، ملفات اختبار آمنة، بيئة اختبار مصرح بها.
- ◀ **المخرج:** حالات اختبار، نتائج موثقة، تقرير، طلب إصلاح.
- ◀ **مثال:** يراجع الفريق واجهة رفع مستندات بملفات اختبار آمنة وحسابات تجريبية.



(الشكل) (Web Application Security Testing) اختبار تطبيقات الويب



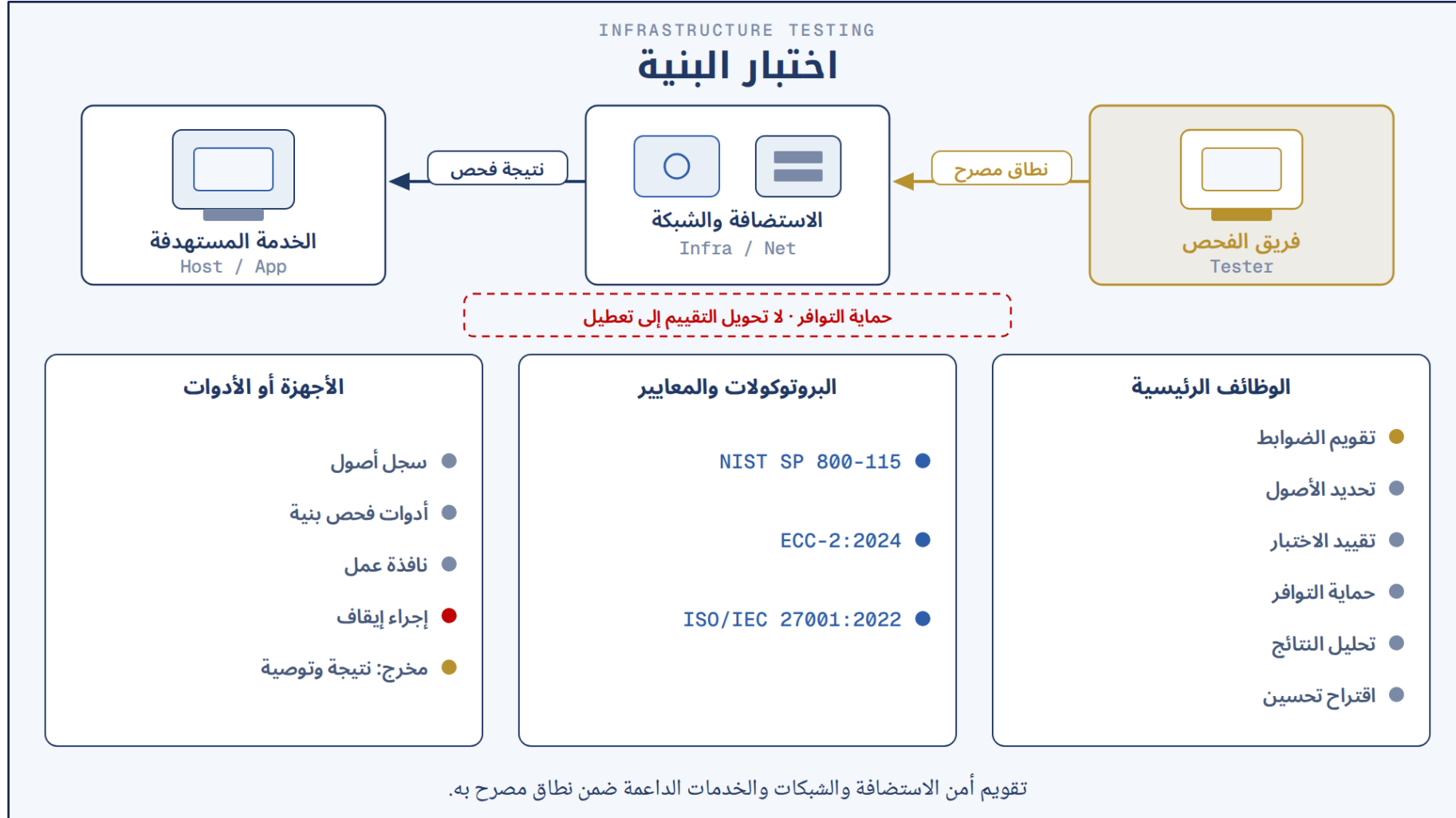


اختبار البنية (Infrastructure Testing)

- ◀ اختبار البنية تقويم أمن مكونات الاستضافة والشبكات والخدمات الداعمة ضمن نطاق مصرح به.
- ◀ وظيفته كشف مؤشرات ضعف مرتبطة بالنظام أو الشبكة أو الضوابط المحيطة بالتطبيق، مع حماية التوافر وعدم تحويل التقييم إلى مصدر تعطيل.
- ◀ **الوظيفة:** تقويم الضوابط التقنية المحيطة بالخدمة.
- ◀ **المسؤوليات:** تحديد الأصول، تقييد الاختبار، حماية التوافر، تحليل النتائج، اقتراح تحسين.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، ECC-2:2024، ISO/IEC 27001:2022.
- ◀ **الأجهزة أو الأدوات:** سجل أصول، أدوات فحص بنية، نافذة عمل، إجراء إيقاف.
- ◀ **المخرج:** نتيجة فحص وملاحظة ضابط وتوصية.
- ◀ **مثال:** يقوم الفريق فصل بيئة الاختبار عن الإنتاج وضوابط الوصول الإداري.



(الشكل) (Infrastructure Testing) اختبار البنية



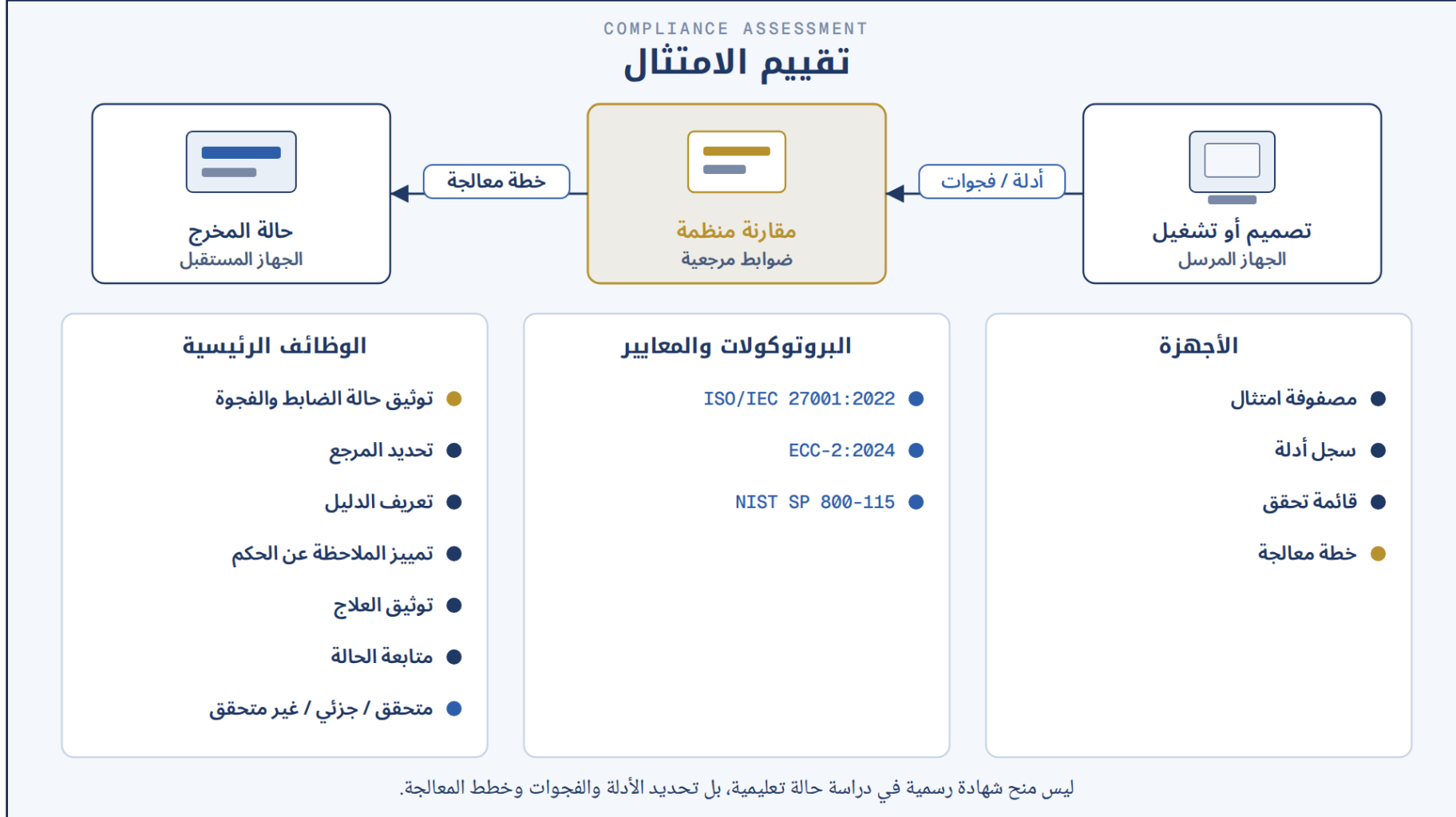


(Compliance Assessment) تقييم الامتثال

- ◀ تقييم الامتثال مقارنة منظمة بين حالة تصميم أو تشغيل ومتطلبات أو ضوابط مرجعية محددة.
- ◀ وظيفته تحديد الأدلة والفجوات وخطط المعالجة، وليس منح شهادة رسمية في دراسة حالة تعليمية.
- ◀ **الوظيفة:** توثيق حالة الضابط والفجوة.
- ◀ **المسؤوليات:** تحديد المرجع، تعريف الدليل، تمييز الملاحظة عن الحكم، توثيق العلاج، متابعة الحالة.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، ECC-2:2024، NIST SP 800-115.
- ◀ **الأجهزة أو الأدوات:** مصفوفة امتثال، سجل أدلة، قائمة تحقق، خطة معالجة.
- ◀ **المخرج:** حالة متحقق أو جزئي أو غير متحقق أو غير منطبق.
- ◀ **مثال:** تقارن المنشأة تصميم الهوية والوصول بفئة ضوابط وتسجل الدليل وخطوة المعالجة.



(الشكل) (Compliance Assessment) تقييم الامتثال



مصفوفة تتبع فجوات الامتثال

شركة الحلول التقنية والخدمات الرقمية						
تطوير وإدارة المتصات الرقمية والخدمات السحابية						
جازان، المملكة العربية السعودية						
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000						
هاتف: 0500000000						
مصفوفة تقييم فجوات الضوابط وخطة المعالجة						
تقييم تصميمي تعليمي مسترشد بفئات الضوابط الأساسية للأمن السبراني						
فئة الضابط	المتطلب التصميمي	الحالة الحالية	نوع الفجوة	الإجراء العلاجي	مالك المعالجة	مؤشر الفعالية
حالة إعادة الاختبار						
إدارة الهوية والتحكم في الوصول	تطبيق المصادقة متعددة العوامل للحسابات الإدارية وتطبيق أقل الامتيازات على العمليات الحساسة.	جزئي	تصميم	إلزام عامل تحقق إضافي للحسابات الإدارية وإعادة اعتماد مصفوفة الأدوار والصلاحيات في الخدمة الخلفية.	الشركة بالتسويق مع العميل	نسبة الحسابات الإدارية الملزمة بالمصادقة متعددة العوامل تساوي 100%. ولا تظهر عمليات حساسة ناجحة خارج الصلاحية المعتمدة.
حماية البيانات أثناء النقل	اعتماد إعدادات حماية متسقة للخدمات المنشورة ومراجعتها ضمن إدارة التغيير.	جزئي	تشغيل	إدراج إعدادات الخادم الوسيط في قالب تغيير موحد ومراجعتها قبل النشر.	الشركة	اجتياز قائمة التحقق للإعدادات في جميع بيئات البوابة المعتمدة دون أثر وظيفي.
النسخ الاحتياطي والاستعادة	تشفير النسخ الاحتياطية وحفظها في موقع معتمد مع سجل تدقيق واختبارات استعادة دورية.	جزئي	تصميم وتشغيل	نقل النسخ إلى مسار مركزي مع سياسة احتفاظ وتسجيل عمليات الاستعادة وتنفيذ اختبار استعادة.	العميل (منشأة سعودية)	نجاح اختبار الاستعادة ضمن الزمن المستهدف ووجود سجل تدقيق قابل للمراجعة لكل عملية.
إدارة الاستثناءات	توثيق أي استثناء أمني بمالك وسبب ومدة انتهاء وموافقة معتمدة.	غير مطبق	تشغيل	إنشاء سجل استثناءات ومراجعتها دورياً، وإغلاق الاستثناءات المنتهية أو تجديدها بموافقة موثقة.	العميل (منشأة سعودية)	لا يوجد استثناء نشط بلا مالك أو تاريخ انتهاء أو موافقة موثقة.
هذه المصفوفة أداة تعليمية لتحديد فجوات وتحسينات تصميمية. لا تمثل إقراراً بالامتثال أو شهادة صادرة من جهة تنظيمية.						
مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية						

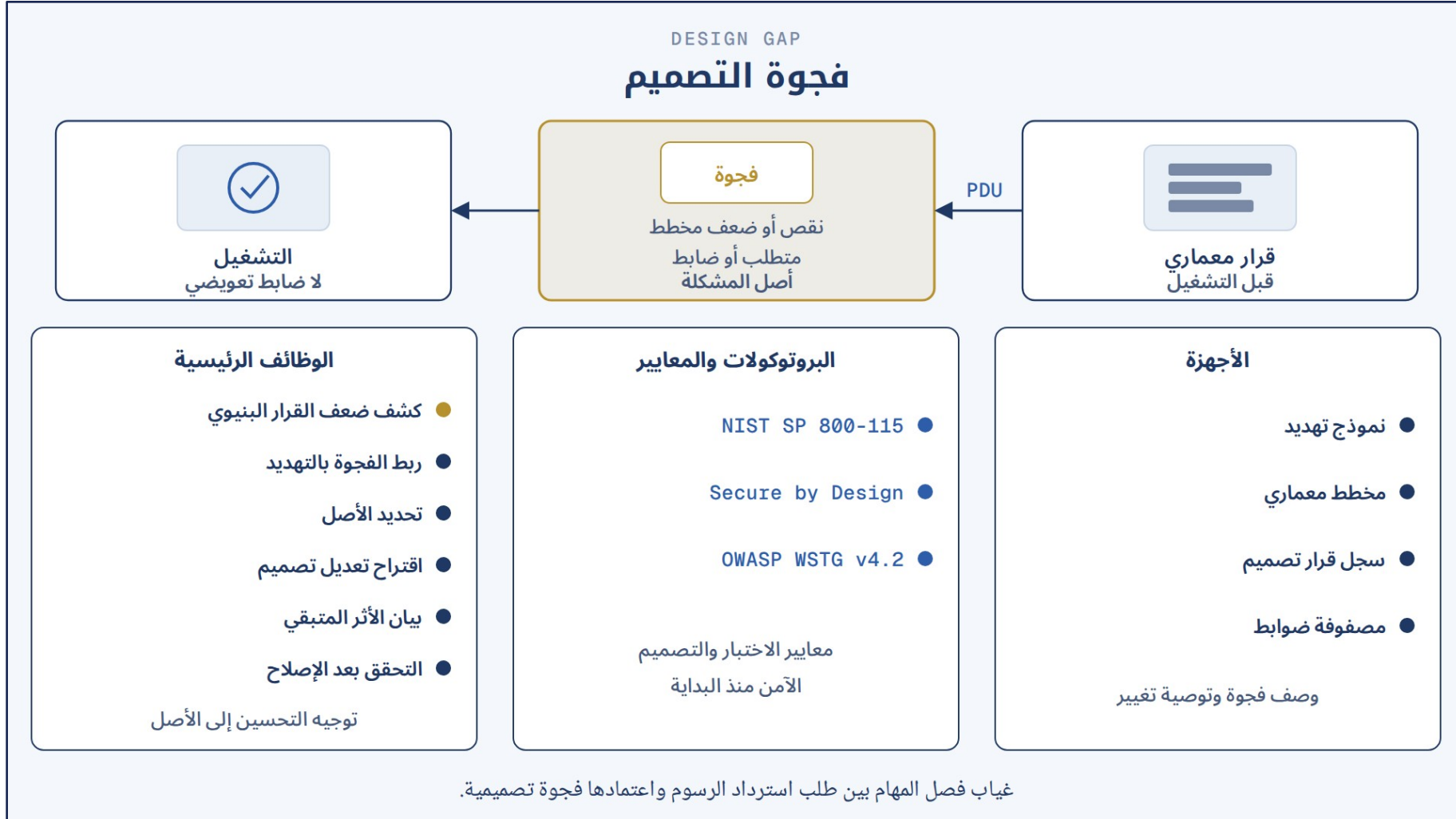
- ◀ ابدأ بصف إدارة الهوية والتحكم في الوصول، حيث الحالة الحالية جزئية والفجوة تصميمية.
- ◀ ثم اقرأ مؤشر الفعالية المحدد، وهو التزام 100% من الحسابات الإدارية بالمصادقة متعددة العوامل.
- ◀ قارن ذلك بصف إدارة الاستثناءات، حيث الحالة غير مطبقة والفجوة تشغيلية، لتفرق بين ضعف القرار وضعف التنفيذ والمتابعة.



- ◀ فجوة التصميم نقص أو ضعف في قرار معماري أو متطلب أو ضابط مخطط قبل التشغيل أو في بنيته.
- ◀ وظيفتها توجيه التحسين إلى أصل المشكلة بدلاً من الاكتفاء بضابط تعويضي مؤقت.
- ◀ **الوظيفة:** كشف ضعف القرار البنيوي.
- ◀ **المسؤوليات:** ربط الفجوة بالتهديد، تحديد الأصل، اقتراح تعديل تصميم، بيان الأثر المتبقي، التحقق بعد الإصلاح.
- ▶ **البروتوكولات والمعايير:** NIST SP 800-115, Secure by Design, OWASP WSTG v4.2.
- ◀ **الأجهزة أو الأدوات:** نموذج تهديد، مخطط معماري، سجل قرار تصميم، مصفوفة ضوابط.
- ◀ **المخرج:** وصف فجوة وتوصية تغيير ومبرر.
- ◀ **مثال:** غياب فصل المهام بين طلب استرداد الرسوم واعتمادها يمثل فجوة تصميمية.



فجوة التصميم (Design Gap) (الشكل)



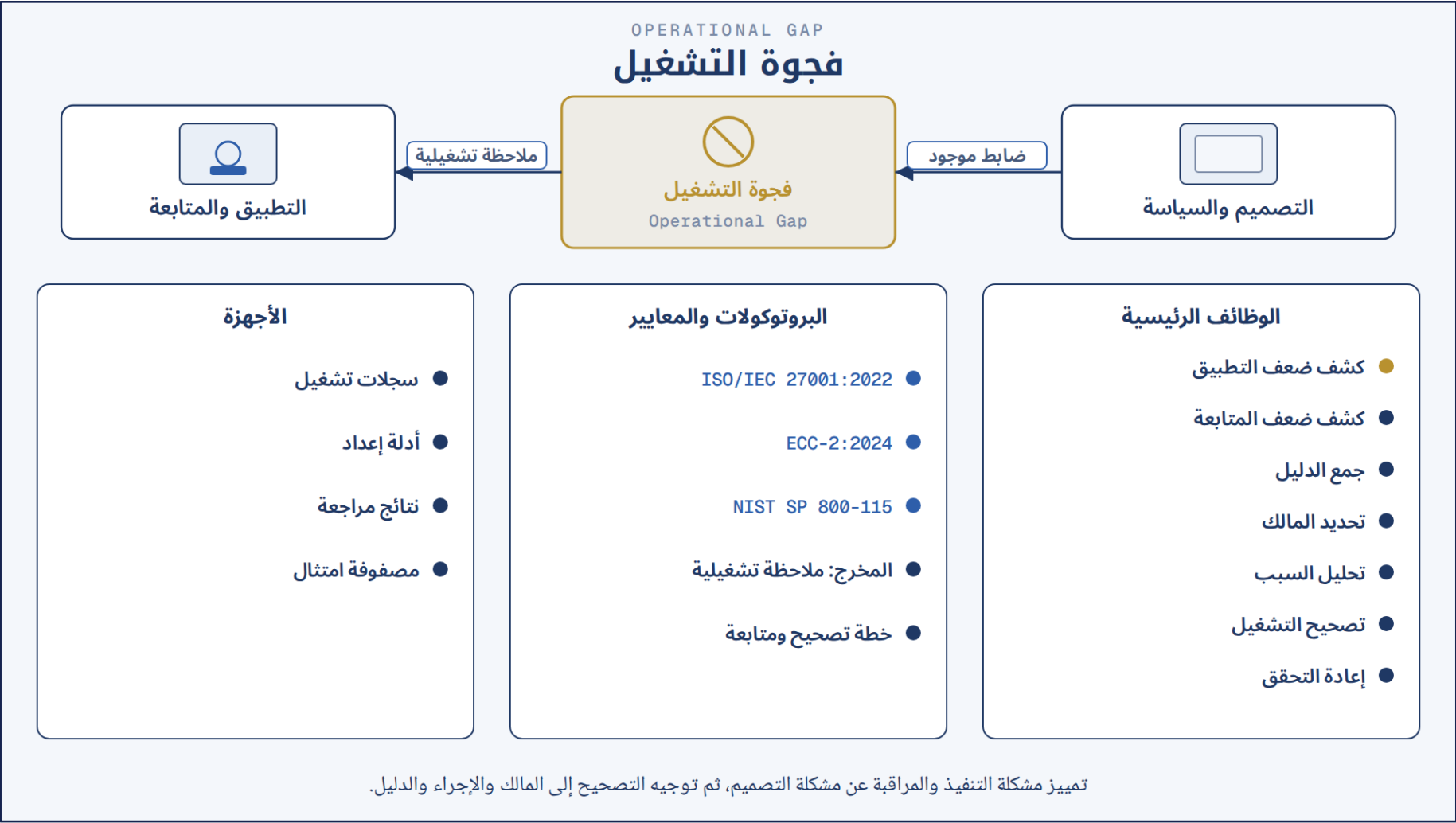


فجوة التشغيل (Operational Gap)

- ◀ فجوة التشغيل ضعف في التطبيق الفعلي أو التشغيل أو المتابعة لضابط موجود في التصميم أو السياسة.
- ◀ وظيفتها تمييز مشكلة التنفيذ والمراقبة من مشكلة التصميم نفسه، ثم توجيه التصحيح إلى المالك والإجراء والدليل.
- ◀ **الوظيفة:** كشف ضعف التطبيق والمتابعة.
- ◀ **المسؤوليات:** جمع الدليل، تحديد المالك، تحليل السبب، تصحيح التشغيل، إعادة التحقق.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، ECC-2:2024، NIST SP 800-115.
- ◀ **الأجهزة أو الأدوات:** سجلات تشغيل، أدلة إعداد، نتائج مراجعة، مصفوفة امتثال.
- ◀ **المخرج:** ملاحظة تشغيلية وخطة تصحيح ومتابعة.
- ◀ **مثال:** وجود سياسة مراجعة صلاحيات دون دليل على تنفيذ المراجعة الدورية يعد فجوة تشغيلية.



فجوة التشغيل (Operational Gap) (الشكل)

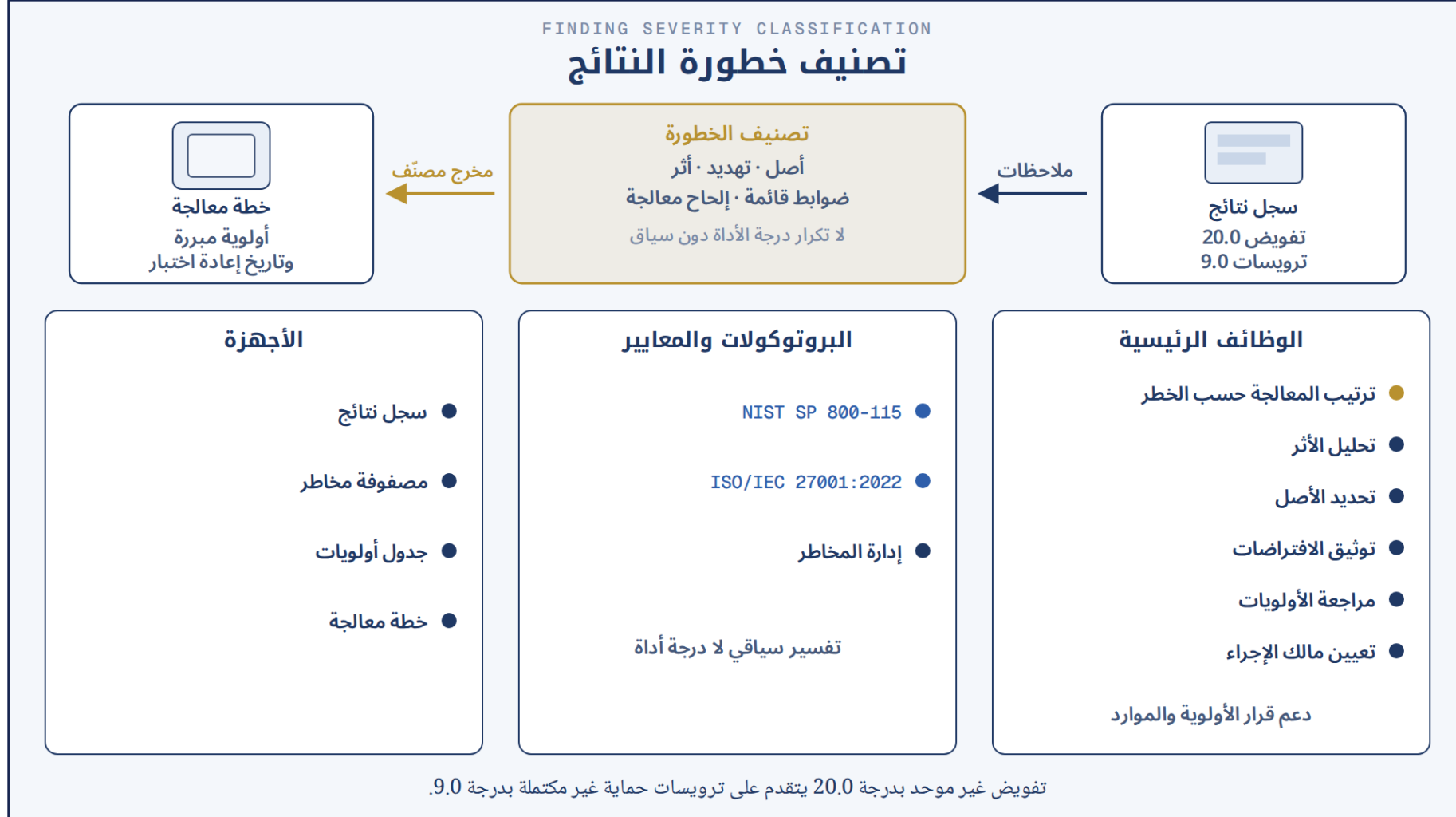




- ◀ تصنيف خطورة النتائج ترتيب للملاحظات وفق الأصل والتهديد والأثر والضوابط القائمة وإلحاح المعالجة.
- ◀ وظيفته دعم قرار الأولوية وتخصيص الموارد للتحسين، لا تكرار درجة أداة دون تفسير سياقي.
- ◀ **الوظيفة:** ترتيب المعالجة حسب الخطر.
- ◀ **المسؤوليات:** تحليل الأثر، تحديد الأصل، توثيق الافتراضات، مراجعة الأولويات، تعيين مالك الإجراء.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، ISO/IEC 27001:2022، إدارة المخاطر.
- ◀ **الأجهزة أو الأدوات:** سجل نتائج، مصفوفة مخاطر، جدول أولويات، خطة معالجة.
- ◀ **المخرج:** أولوية مبررة وتاريخ إعادة اختبار.
- ◀ **مثال:** تقدم ملاحظة تفويض غير موحد بدرجة خطر 20.0 على ترويسات حماية غير مكتملة بدرجة 9.0.



(الشكل) (Finding Severity Classification) تصنيف خطورة النتائج

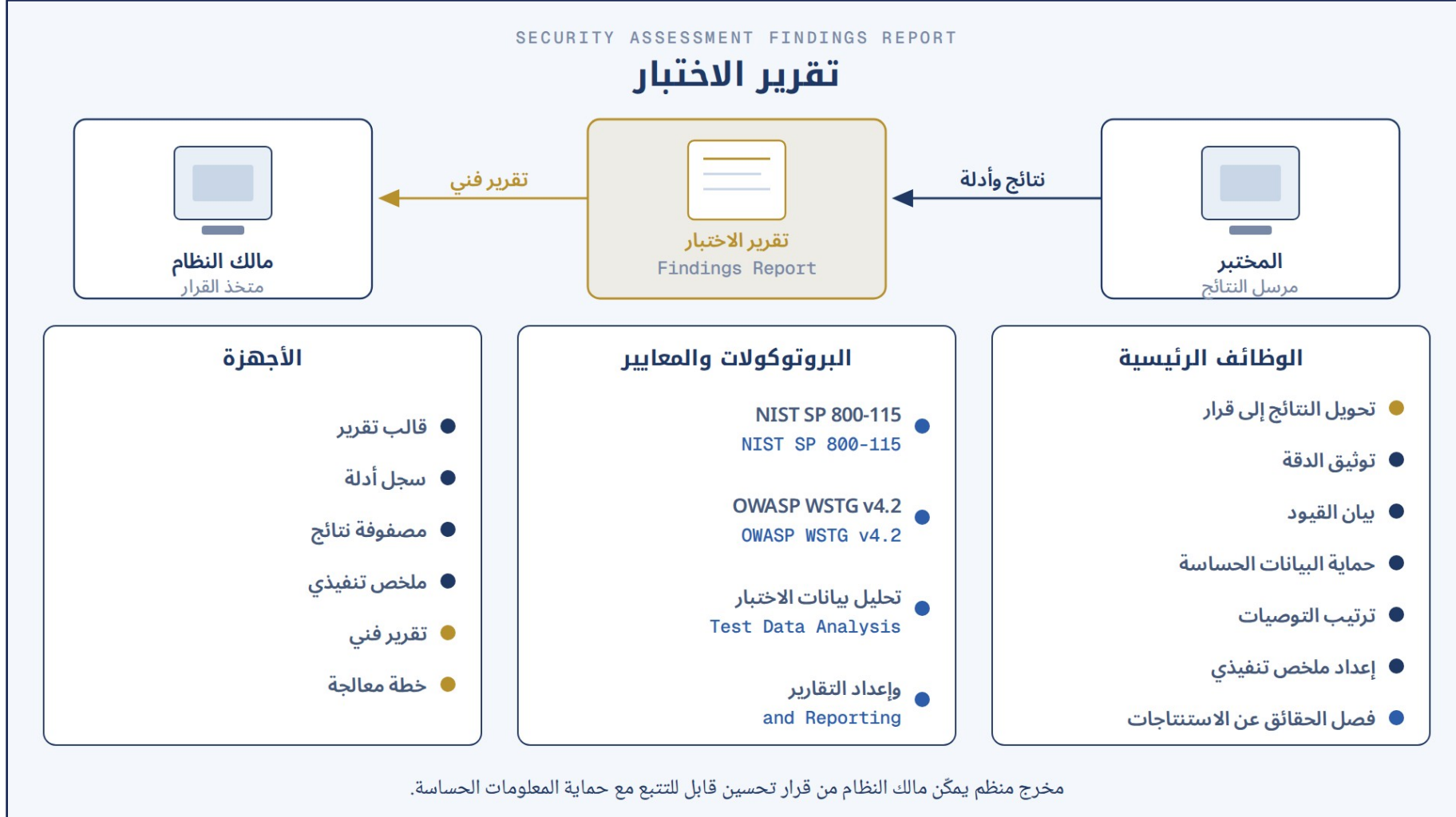




- ◀ تقرير الاختبار مخرج منظم يوثق الهدف والنطاق والمنهجية والنتائج والأثر والتوصيات والقيود.
- ◀ وظيفته تمكين مالك النظام من اتخاذ قرار تحسين قابل للتتبع مع حماية المعلومات الحساسة وفصل الحقائق عن الاستنتاجات.
- ◀ **الوظيفة:** تحويل النتائج إلى قرار قابل للمراجعة.
- ◀ **المسؤوليات:** توثيق الدقة، بيان القيود، حماية البيانات الحساسة، ترتيب التوصيات، إعداد ملخص تنفيذي.
- ▶ **المعايير:** NIST SP 800-115, OWASP WSTG v4.2, Security Test Data Analysis and Reporting.
- ◀ **الأجهزة أو الأدوات:** قالب تقرير، سجل أدلة، مصفوفة نتائج، ملخص تنفيذي.
- ◀ **المخرج:** تقرير فني وخطة معالجة.
- ◀ **مثال:** يفرق التقرير بين نتيجة مؤكدة وملاحظة تحتاج تحققاً في بوابة جامعية.



(الشكل) (Security Assessment Findings Report) تقرير الاختبار



قراءة تقرير نتائج اختبار

شركة الحلول التقنية والخدمات الرقمية						
تطوير وإدارة المنصات الرقمية والخدمات السحابية						
جاران، المملكة العربية السعودية						
الرقم الضريبي: 3000000000000003 · السجل التجاري: 1010000000						
هاتف: 0500000000						
المستند: جدول نتائج تقييم أمان البوابة						
جدول نتائج تقييم أمان البوابة						
نتائج تعليمية مستخرجة من اختبار مصرح به خلال نافذة مارس 2026						
الملاحظة	الأصل المتأثر	وصف النتيجة	الخطورة	نوع الفجوة	الأثر المحتمل	قرار التحسين الأولي
1	خدمة إدارة صلاحيات المستخدمين	التحقق من صلاحية بعض العمليات يعتمد على الواجهة الأمامية ولا يوجد تحقق موحد كافٍ في طبقة الخدمة الخلفية.	عالية	تصميم	احتمال تنفيذ مستخدم مصرح له لعملية خارج حدود دوره المحدد.	تطبيق قرار تفويض مركزي في الخدمة الخلفية وربط كل عملية بمصفوفة أدوار وصلاحيات معتمدة.
2	الخدم الوسيط للبوابة	إعدادات الحماية الخاصة بترويسات الاستجابة غير مكتملة في البيئة التجريبية.	متوسطة	تشغيل	الحفاض طبقة الحماية الوقائية في متصفح المستخدم مقارنة بالضبط المستهدف.	اعتماد إعداد موحّد للخدم الوسيط ضمن إدارة التغيير ومراجعتها قبل النشر.
3	نسخ قاعدة البيانات التجريبية	توجد نسخة احتياطية تجريبية خارج موقع التخزين المعتمد، ولا يوجد سجل مراجعة مكتمل لإجراءات الاستعادة.	متوسطة	تصميم وتشغيل	ضعف القدرة على إثبات سلامة النسخ والاستعادة المنظمة عند الحاجة.	تصميم مسار نسخ احتياطي مركزي مشفر مع سياسة احتفاظ وسجل تدقيق واختبار استعادة دوري.
4	حسابات مشرفي النظام	لا يفرض التصميم التحقق متعدد العوامل على جميع حسابات الإدارة ذات الامتياز العالي.	عالية	تصميم	ارتفاع أثر الاستيلاء على حساب إداري على الخدمات والبيانات.	إلزام المصادقة متعددة العوامل للحسابات الإدارية ومراجعة الاستثناءات وفق مبدأ أقل الامتيازات.
						لا يمكن للحساب الإداري التجريبي إكمال تسجيل الدخول دون عامل تحقق إضافي مع توثيق الاستثناءات المعتمدة فقط.
مستند تعليمي لأعراض تعليمية وتحدد بعد تقدير الأصل المتأثر واحتمال الأثر. لا يتضمن الجدول أساليب استغلال أو تعليمات تشغيلية.						
مستند تعليمي افتراضي: الأسماء والأرقام غير حقيقية						

- ❖ اقرأ الملاحظة الأولى المتعلقة بخدمة إدارة صلاحيات المستخدمين.
- ❖ تصنف خطورتها عالية لأنها تسمح بعملية خارج حدود الدور عند غياب تحقق موحد في الخدمة الخلفية.
- ❖ يختلف ذلك عن الملاحظة الثانية التي تصنف فجوة تشغيلية متوسطة في ترويسات الحماية.
- ❖ انتقل من الوصف إلى قرار التحسين ثم إلى معيار إعادة الاختبار لكل ملاحظة.
- ❖ التعليق: يرتبط تصنيف الملاحظة بسببها الجذري وأصلها المتأثر، لذلك لا يعالج ضعف التفويض بالطريقة نفسها التي يعالج بها إعداد تشغيلي ناقص.



◀ مثال محلول:

◀ **المعطيات:** يتضمن التقرير أربع ملاحظات، اثنتان عاليتا الخطورة واثنتان متوسطتا الخطورة، منها ملاحظتان تصميميتان وملاحظة تشغيلية وملاحظة تصميم وتشغيل.

◀ الخطوات:

1. نعد الملاحظات العالية، فنحصل على 2 من أصل 4.
2. نحسب نسبتها: $2 / 4 \times 100 = 50\%$.
3. نربط كل ملاحظة بقرار التحسين ومعيار إعادة الاختبار الموثق في التقرير.



قراءة تقرير نتائج اختبار (تابع)

الملاحظة	الخطورة	نوع الفجوة	قرار التحسين
1	عالية	تصميم	تفويض مركزي في الخدمة الخلفية
2	متوسطة	تشغيل	إعداد موحد للخادم الوسيط
3	متوسطة	تصميم وتشغيل	مسار نسخ مركزي مشفر
4	عالية	تصميم	مصادقة متعددة العوامل

النتائج: تمثل الملاحظات العالية 50% من التقرير، فتبدأ المعالجة بقراري التفويض المركزي والمصادقة متعددة العوامل مع تطبيق معايير إعادة الاختبار المحددة.



قراءة تقرير نتائج اختبار (تابع)

- ◀ التعليل: تختلف المعالجة لأن سبب الملاحظة قد يكون قراراً تصميمياً أو إعداداً تشغيلياً، حتى لو وردت النتائج في التقرير نفسه.
- ◀ **مثال محلول:**
- ◀ **المعطيات:** يحتوي التقرير على 4 ملاحظات.
- ◀ الملاحظتان 1 و 4 عاليتا الخطورة ومن نوع فجوة التصميم.
- ◀ الملاحظة 2 متوسطة ومن نوع فجوة التشغيل.
- ◀ الملاحظة 3 متوسطة ومن نوع تصميم وتشغيل.
- ◀ **الخطوات:**
- 1. نعد ملاحظات التصميم الخالص، فنحصل على 2.
- 2. نحسب نسبتها من التقرير: $2 / 4 \times 100 = 50\%$.
- 3. نربط الملاحظة 2 بإعداد الخادم الوسيط، ونربط الملاحظة 4 بفرض المصادقة متعددة العوامل.



نوع الفجوة	عدد الملاحظات	قرار أولي
تصميم	2	تعديل الضابط
تشغيل	1	تصحيح الإعداد
تصميم وتشغيل	1	تعديل ومتابعة

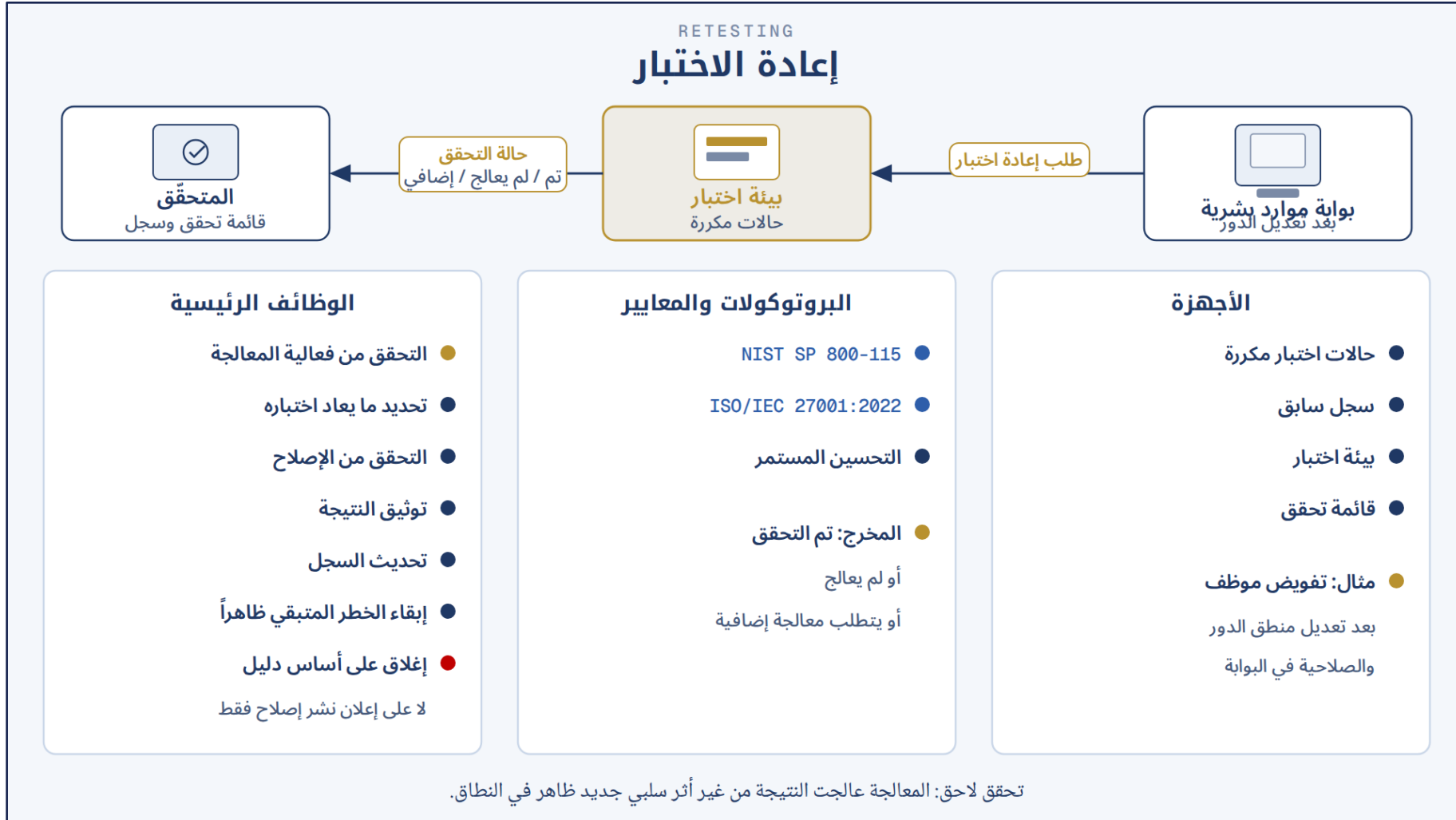
النتائج: تشكل فجوات التصميم 50% من التقرير، فتنطلب تعديل الضوابط، بينما تعالج فجوة التشغيل بإعداد موحد ومراجعة قبل النشر.



- ◀ إعادة الاختبار تحقق لاحق من أن المعالجة عالجت النتيجة من غير خلق أثر سلبي جديد ظاهر في النطاق.
- ◀ وظيفتها إغلاق النتيجة على أساس دليل، لا على أساس إعلان نشر إصلاح فقط.
- ◀ **الوظيفة:** التحقق من فعالية المعالجة.
- ◀ **المسؤوليات:** تحديد ما يعاد اختبار، التحقق من الإصلاح، توثيق النتيجة، تحديث السجل، إبقاء الخطر المتبقي ظاهراً.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، ISO/IEC 27001:2022، التحسين المستمر.
- ◀ **الأجهزة أو الأدوات:** حالات اختبار مكررة، سجل سابق، بيئة اختبار، قائمة تحقق.
- ◀ **المخرج:** حالة تم التحقق أو لم يعالج أو يتطلب معالجة إضافية.
- ◀ **مثال:** يعاد اختبار تفويض موظف بعد تعديل منطق الدور والصلاحيات في بوابة موارد بشرية.



إعادة الاختبار (Retesting) (الشكل)





تحسين التصميم (Design Improvement)

- ◀ تحسين التصميم تعديل منظم للمتطلبات أو المعمارية أو الضوابط أو سير العمل استناداً إلى نتيجة أو خطر أو فجوة.
- ◀ وظيفته تقليل احتمال المشكلة أو أثرها وتحسين تحمل النظام للخطأ والهجوم.
- ◀ **الوظيفة:** تحويل الملاحظة إلى تغيير محدد.
- ◀ **المسؤوليات:** تحليل السبب، مقارنة البدائل، تحديد المالك، تطبيق العلاج، إعادة الاختبار، توثيق القرار.
- ▶ **البروتوكولات والمعايير:** NIST SP 800-115, ISO/IEC 27001:2022, Secure by Design.
- ◀ **الأجهزة أو الأدوات:** سجل قرارات، نموذج تهديد، مصفوفة مخاطر، خطة معالجة.
- ◀ **المخرج:** قرار محسّن وخطة تنفيذ ودليل تحقق.
- ◀ **مثال:** يستبدل الفريق صلاحية واسعة بتفويض مركزي مقيد بالدور ثم يعيد اختبارها.



تحسين التصميم (Design Improvement) (الشكل)





(Exception Management) إدارة الاستثناءات

- ◀ إدارة الاستثناءات توثيق قبول محدود ومؤقت لخطر أو عدم تطبيق ضابط، مع مبرر ومالك وضابط تعويضي ومراجعة لاحقة.
- ◀ وظيفتها منع تحول الاستثناء غير الموثق إلى تجاوز دائم للضوابط.
- ◀ **الوظيفة:** ضبط الخطر المقبول مؤقتاً.
- ◀ **المسؤوليات:** تحديد السبب، تقدير الخطر، اعتماد صاحب صلاحية، وضع ضابط تعويضي، تحديد تاريخ انتهاء.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، ECC-2:2024، إدارة المخاطر، التحسين المستمر.
- ◀ **الأجهزة أو الأدوات:** سجل استثناءات، سجل مخاطر متبقية، خطة معالجة.
- ◀ **المخرج:** طلب استثناء وقرار اعتماد ومراجعة.
- ◀ **مثال:** يؤجل إصلاح نظام قديم مع عزل إضافي ومراقبة وتاريخ إنهاء واضح.



إدارة الاستثناءات (Exception Management) (الشكل)

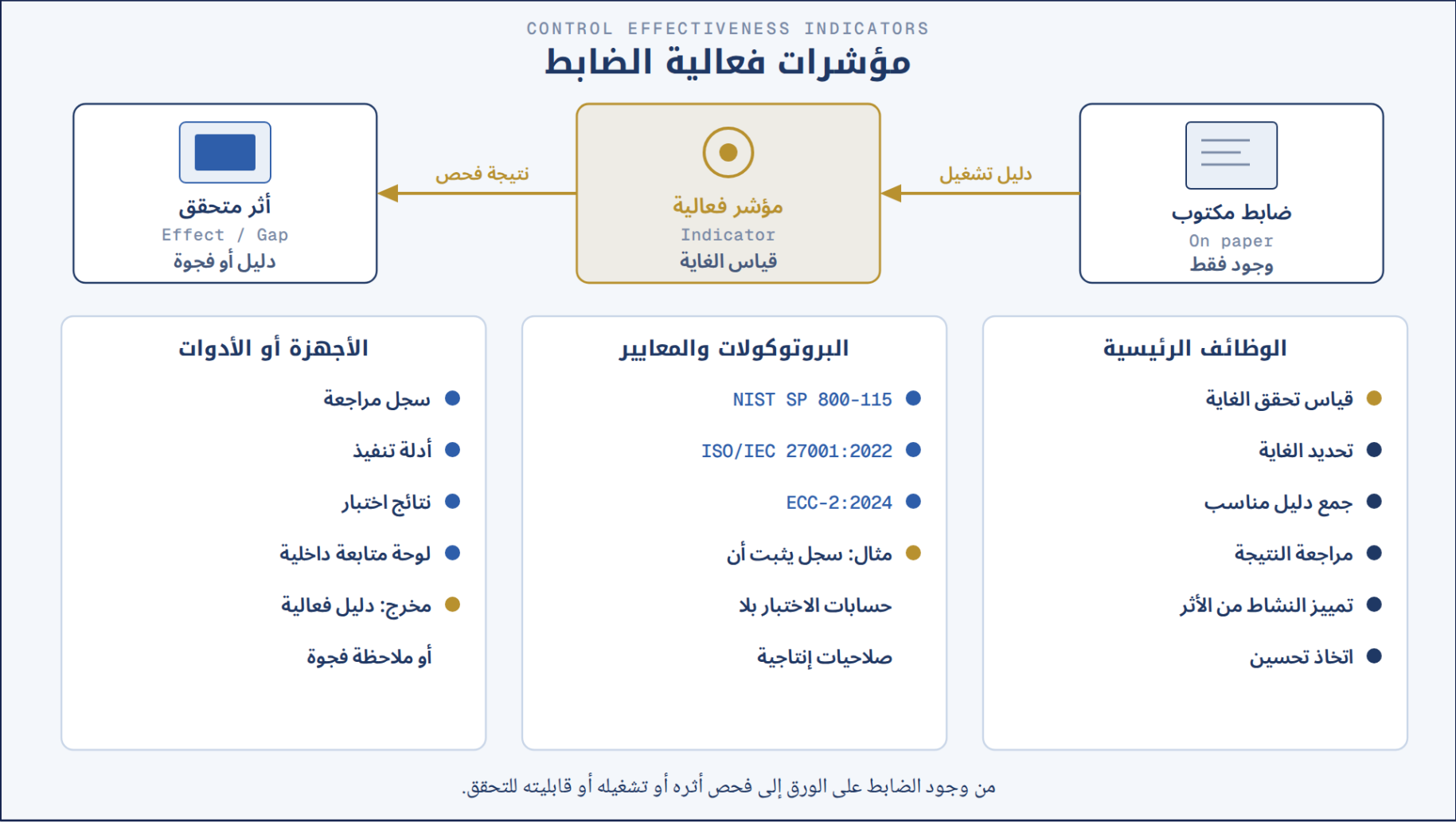




- ◀ مؤشرات فعالية الضابط أدلة أو مقاييس تساعد على تقدير ما إذا كان الضابط يحقق غايته في السياق المحدد.
- ◀ وظيفتها الانتقال من وجود الضابط على الورق إلى فحص أثره أو تشغيله أو قابليته للتحقق.
- ◀ **الوظيفة:** قياس تحقق الغاية الأمنية للضابط.
- ◀ **المسؤوليات:** تحديد الغاية، جمع دليل مناسب، مراجعة النتيجة، تمييز النشاط من الأثر، اتخاذ تحسين.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، ISO/IEC 27001:2022، ECC-2:2024.
- ◀ **الأجهزة أو الأدوات:** سجل مراجعة، أدلة تنفيذ، نتائج اختبار، لوحة متابعة داخلية.
- ◀ **المخرج:** دليل فعالية أو ملاحظة فجوة.
- ◀ **مثال:** يثبت السجل أن حسابات الاختبار لا تحمل صلاحيات إنتاجية.



(الشكل) (Control Effectiveness Indicators) مؤشرات فعالية الضابط



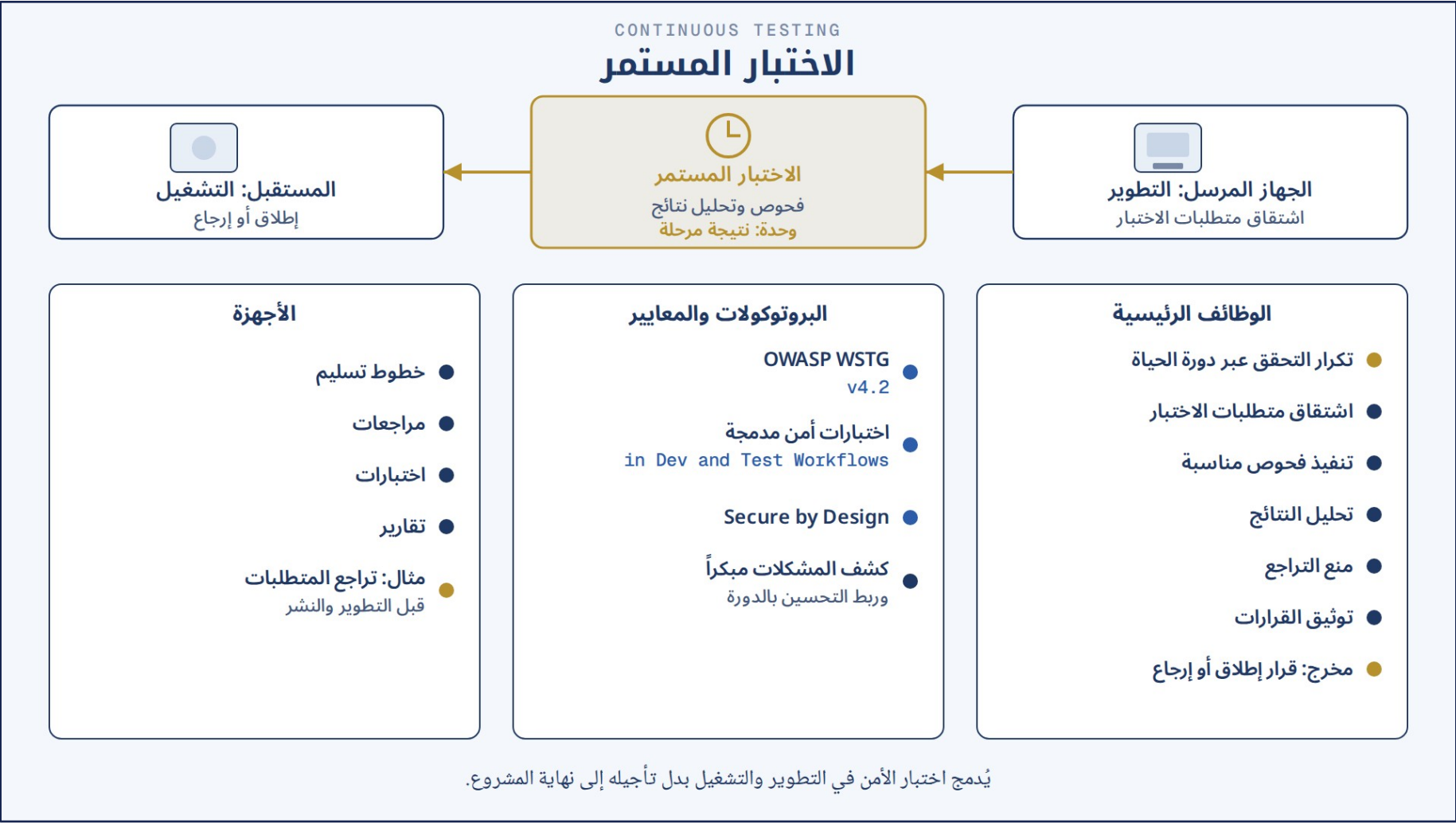


(Continuous Testing) الاختبار المستمر

- ◀ الاختبار المستمر إدماج متطلبات اختبار الأمن وتحليل نتائجه في دورة التطوير والتشغيل بدلاً من تأجيله إلى نهاية المشروع.
- ◀ وظيفته كشف المشكلات مبكراً وربط التحسين بأنشطة دورة الحياة المتكررة.
- ◀ **الوظيفة:** تكرار التحقق عبر دورة الحياة.
- ◀ **المسؤوليات:** اشتقاق متطلبات الاختبار، تنفيذ فحوص مناسبة، تحليل النتائج، منع التراجع، توثيق القرارات.
- ▶ **المعايير:** OWASP WSTG v4.2, Security Tests Integrated in Development and Testing Workflows, Secure by Design.
- ◀ **الأجهزة أو الأدوات:** خطوط تسليم، مراجعات، اختبارات، تقارير.
- ◀ **المخرج:** نتيجة مرحلة وقرار إطلاق أو إرجاع.
- ◀ **مثال:** تراجع المتطلبات قبل التطوير والتصميم قبل البناء والضوابط قبل النشر.



الاختبار المستمر (Continuous Testing) (الشكل)



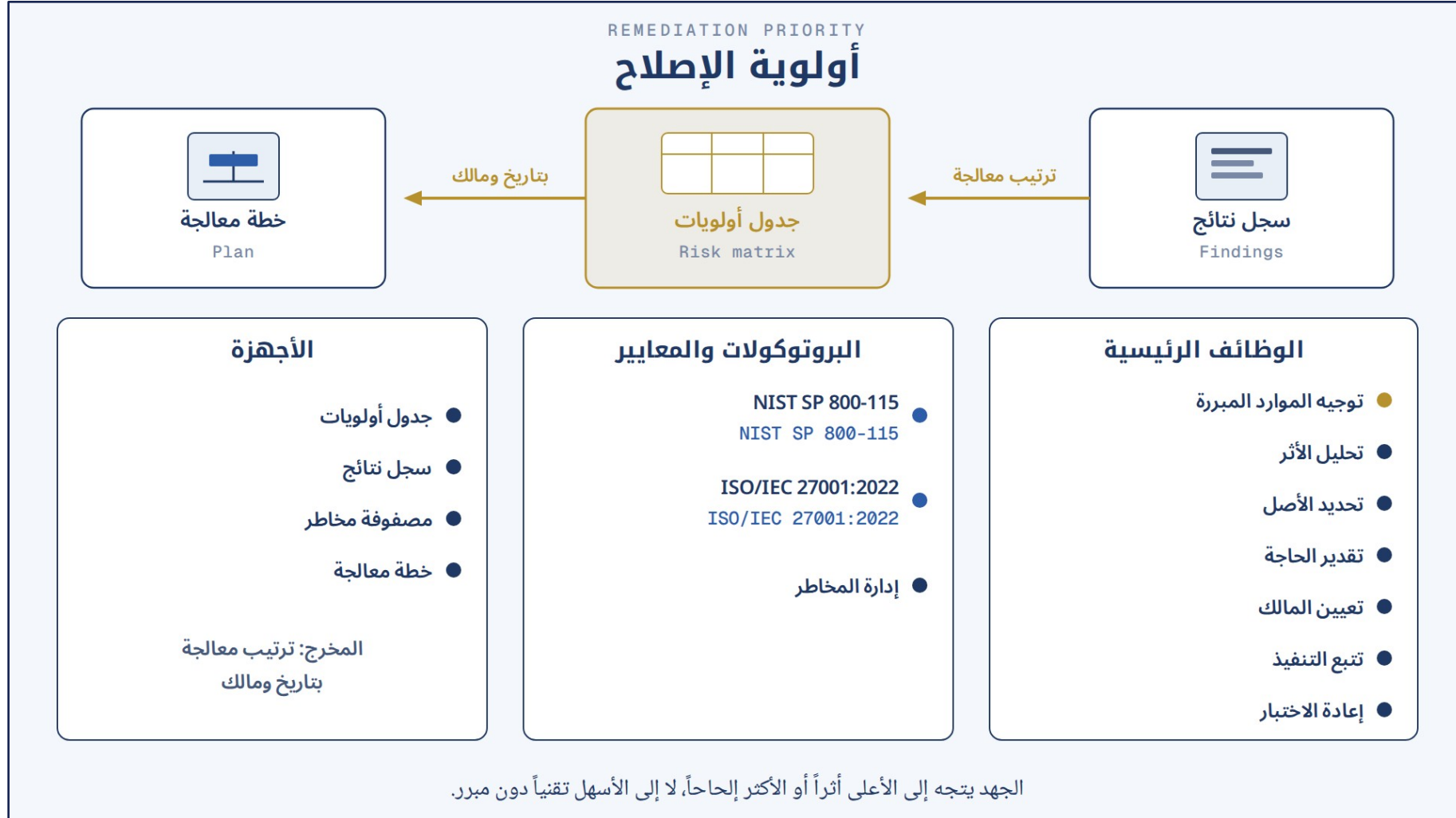


(Remediation Priority) أولوية الإصلاح

- ◀ أولوية الإصلاح ترتيب المعالجات وفق خطر النتيجة والسياق والأصل والضوابط القائمة وموارد المعالجة.
- ◀ وظيفتها توجيه الجهد إلى المشكلات الأعلى أثراً أو الأكثر إلحاحاً، بدلاً من اختيار الأسهل تقنياً دون مبرر.
- ◀ **الوظيفة:** توجيه الموارد إلى المعالجة المبررة.
- ◀ **المسؤوليات:** تحليل الأثر، تحديد الأصل، تقدير الحاجة، تعيين المالك، تتبع التنفيذ، إعادة الاختبار.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، ISO/IEC 27001:2022، إدارة المخاطر.
- ◀ **الأجهزة أو الأدوات:** جدول أولويات، سجل نتائج، مصفوفة مخاطر، خطة معالجة.
- ◀ **المخرج:** ترتيب معالجة بتاريخ ومالك.
- ◀ **مثال:** تعالج المنشأة غياب العامل الإضافي للحسابات الإدارية قبل تحسين رسالة خطأ عامة.



(الشكل) (Remediation Priority) أولوية الإصلاح



مثال محلول على النموذج، ترتيب أولويات المعالجة

الجدول: مصفوفة أولوية معالجة نتائج اختبار الأمان

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

مصفوفة أولوية معالجة نتائج اختبار الأمان

مقياس الاحتمال والأثر من 1 إلى 5، درجة الخطر تساوي الاحتمال مضروباً في الأثر

الملاحظة	الأصل	الاحتمال	الأثر	درجة الخطر	المدة المستهدفة للمعالجة بالأيام	قرار التحسين	موعد إعادة الاختبار

تستخدم الدرجة لترتيب العمل التعليمي ولا تغني عن تقدير مالك الأصل ومدير المخاطر للسياق التشغيلي الفعلي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- المعطيات: لدى المنشأة أربع ملاحظات.
- الملاحظة الأولى تفويض غير موحد باحتمال 4 وأثر 5، والملاحظة الثانية ترويسات حماية غير مكتملة باحتمال 3 وأثر 3. الملاحظة الثالثة نسخ احتياطي وسجل استعادة باحتمال 3 وأثر 4. الملاحظة الرابعة غياب عامل إضافي للإدارة باحتمال 4 وأثر 5.

الخطوة 1 من 3: تسجيل المعطيات وقرارات التحسين

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000000 - السجل التجاري: 1010000000
هاتف: 0500000000

الجدول: مصفوفة أولوية معالجة نتائج اختبار الأمان

مصفوفة أولوية معالجة نتائج اختبار الأمان

مقياس الاحتمال والأثر من 1 إلى 5، درجة الخطر تساوي الاحتمال مضروباً في الأثر

الملاحظة	الأصل	الاحتمال	الأثر	درجة الخطر	المدة المستهدفة للمعالجة بالأيام	قرار التحسين	مؤعد إعادة الاختبار
الملاحظة 1: تفويض غير موحد	خدمة إدارة صلاحيات المستخدمين	4	5		9	إعادة بناء قرار التفويض في طبقة الخدمة الخلفية وربطه بمصفوفة الصلاحيات.	2026-04-08
الملاحظة 2: ترويسات حماية غير مكتملة	الخادم الوسيط للبوابات	3	3		18	توحيد إعداد الحماية ضمن إجراء تغيير معتمد ومراجع.	2026-04-20
الملاحظة 3: نسخ احتياطي وسجل استعادة	نسخ قاعدة البيانات التجريبية	3	4		16	تفعيل مسار نسخ مركزي مشفر واختبار الاستعادة الموثق.	2026-04-18
الملاحظة 4: غياب عامل إضافي للإدارة	حسابات مشرفي النظام	4	5		11	فرض المصادقة متعددة العوامل على الحسابات الإدارية ومراجعة الاستثناءات.	2026-04-10

تستخدم الدرجة لترتيب العمل التعليمي ولا تغني عن تقدير مالك الأصل ومدير المخاطر للسياق التشغيلي الفعلي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يسجل النموذج الأصل والاحتمال والأثر والمدة المستهدفة لكل ملاحظة.
- الملاحظة الأولى تخص خدمة إدارة صلاحيات المستخدمين ومدتها المستهدفة 9 أيام، بينما تخص الرابعة حسابات مشرفي النظام ومدتها 11 يوماً.
- تكتب قرارات التحسين وموعدا إعادة الاختبار 2026-04-08 و2026-04-10 قبل ترتيب الأولوية.

الخطوة 2 من 3: حساب درجة الخطر

شركة الحلول التقنية والخدمات الرقمية						
تطوير وإدارة المنصات الرقمية والخدمات السحابية						
جازان، المملكة العربية السعودية						
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000						
هاتف: 0500000000						
مصفوفة أولوية معالجة نتائج اختبار الأمان						
مقياس الاحتمال والأثر من 1 إلى 5، درجة الخطر تساوي الاحتمال مضروباً في الأثر						
الملاحظة	الأصل	الاحتمال	الأثر	درجة الخطر	المدة المستهدفة للمعالجة بالأيام	قرار التحسين
الملاحظة 1: تفويض غير موحد	خدمة إدارة صلاحيات المستخدمين	4	5	20.00	9	إعادة بناء قرار التفويض في طبقة الخدمة الخلفية وربطه بمصفوفة الصلاحيات.
الملاحظة 2: ترويسات حماية غير مكتملة	الخادم الوسيط للبوابة	3	3	9.00	18	توحيد إعدادات الحماية ضمن إجراء تغيير معتمد ومراجع.
الملاحظة 3: نسخ احتياطي وسجل استعادة	نسخ قاعدة البيانات التجريبية	3	4	12.00	16	تفعيل مسار نسخ مركزي مشفر واختبار الاستعادة الموقت.
الملاحظة 4: غياب عامل إضافي للإدارة	حسابات مشرفي النظام	4	5	20.00	11	فرض المصادقة متعددة العوامل على الحسابات الإدارية ومراجعة الاستثناءات.
تستخدم الدرجة لترتيب العمل التعليمي ولا تعني عن تقدير مالك الأصل ومدير المخاطر للسباق التشغيلي الفعلي.						
مستند تعليمي إلكتروسي، الأسماء والأرقام غير حقيقية						

- تطبق القاعدة درجة الخطر = الاحتمال × الأثر على كل صف.
- تنتج الملاحظة الأولى $20.0 = 5 \times 4$ ، والثانية $9.0 = 3 \times 3$ ، والثالثة $12.0 = 4 \times 3$ ، والرابعة $20.0 = 5 \times 4$.
- تدعم الدرجة قرار الترتيب، لكنها تقرأ مع الأصل والضوابط القائمة.
- التعليق: تساوي درجتين لا يلغي مقارنة الأصل المتأثر وقرار التحسين وموعد إعادة الاختبار لكل منهما.



الخطوة 2 من 3: حساب درجة الخطر (تابع)



◀ مثال محلول:

◀ المعطيات: درجة الملاحظة الأولى 20.0 ودرجة الثانية 9.0 ودرجة الثالثة 12.0 ودرجة الرابعة 20.0.

◀ الخطوات:

1. نجمع الدرجات: $61.0 = 20.0 + 12.0 + 9.0 + 20.0$.
2. نقسم المجموع على عدد الملاحظات: $15.25 = 61.0 / 4$.
3. نحدد أعلى درجة، وهي 20.0، ونراجع الأصل وموعد إعادة الاختبار للملاحظتين المتساويتين.



الخطوة 2 من 3: حساب درجة الخطر (تابع)

الملاحظة	درجة الخطر	موعد إعادة الاختبار
تفويض غير موحد	20.0	2026-04-08
ترويسات حماية غير مكتملة	9.0	2026-04-20
نسخ احتياطي وسجل استعادة	12.0	2026-04-18
غياب عامل إضافي للإدارة	20.0	2026-04-10

النتيجة: متوسط درجات الخطر 15.25 وأعلىها 20.0، فتتقدم الملاحظتان الأولى والرابعة إلى قرار معالجة مبرر لا آلي.



الخطوة 2 من 3: حساب درجة الخطر (تابع)

◀ التعليل: تدعم المعادلة ترتيب النتائج، لكنها لا تحل محل مراجعة الأصل المتأثر وقرار التحسين وموعد إعادة الاختبار.

◀ مثال محلول:

◀ **المعطيات:** درجتا الملاحظة 1 والملاحظة 4 تساويان 20.0. تخص الأولى خدمة إدارة صلاحيات المستخدمين وموعد إعادة اختبارها 2026-04-08. تخص الرابعة حسابات مشرفي النظام وموعد إعادة اختبارها 2026-04-10.

◀ الخطوات:

1. نثبت أن الفرق الحسابي بين الدرجتين هو $20.0 - 20.0 = 0$.
2. نقارن الأصلين المتأثرين بدلاً من كسر التعادل عشوائياً.
3. نقرأ مواعييد إعادة الاختبار، فنجد فرقاً زمنياً مقداره يومان.



الخطوة 2 من 3: حساب درجة الخطر (تابع)

الملاحظة	درجة الخطر	موعد إعادة الاختبار
تفويض غير موحد	20.0	2026-04-08
غياب عامل إضافي للإدارة	20.0	2026-04-10

النتائج: لا يحسم التعادل بالدرجة وحدها، ويوثق قرار ترتيب المعالجة بعد مقارنة الأصليين وموعد التحقق اللاحقين.

الخطوة 3 من 3: قراءة النموذج المكتمل

الجدول: مصفوفة أولوية معالجة نتائج اختبار الأمان

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

مصفوفة أولوية معالجة نتائج اختبار الأمان

مقياس الاحتمال والأثر من 1 إلى 5، درجة الخطر تساوي الاحتمال مضروباً في الأثر

الملاحظة	الأصل	الاحتمال	الأثر	درجة الخطر	المدة المستهدفة للمعالجة بالأيام	قرار التحسين	موعد إعادة الاختبار
الملاحظة 1: تفويض غير موحد	خدمة إدارة صلاحيات المستخدمين	4	5	20.00	9	إعادة بناء قرار التفويض في طبقة الخدمة الخلفية وربطه بمصفوفة الصلاحيات.	2026-04-08
الملاحظة 2: ترويسات حماية غير مكتملة	الخادم الوسيط للبوابة	3	3	9.00	18	توحيد إعداد الحماية ضمن إجراء تغيير معتمد ومراجع.	2026-04-20
الملاحظة 3: نسخ احتياطي وسجل استعادة	نسخ قاعدة البيانات التجريبية	3	4	12.00	16	تفعيل مسار نسخ مركزي مشفر واختبار الاستعادة الموثق.	2026-04-18
الملاحظة 4: غياب عامل إضافي للإدارة	حسابات مشرفي النظام	4	5	20.00	11	فرض المصادقة متعددة العوامل على الحسابات الإدارية ومراجعة الاستثناءات.	2026-04-10
متوسط درجة الخطر							15.25
أعلى درجة خطر							20.00

تستخدم الدرجة لترتيب العمل التعليمي ولا تغني عن تقدير مالك الأصل ومدير المخاطر للسياق التشغيلي الفعلي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يظهر النموذج المكتمل متوسط درجة خطر يساوي 15.25 وأعلى درجة تساوي 20.0. لذلك تبدأ المنشأة بمعالجة التفويض غير الموحد وغياب العامل الإضافي للحسابات الإدارية.
- تحدد المصفوفة موعد إعادة اختبار الأولى في 2026-04-08 والرابعة في 2026-04-10 للتحقق من فاعلية التحسين.

الجدول: مصفوفة أولوية معالجة نتائج اختبار الأمان

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

مصفوفة أولوية معالجة نتائج اختبار الأمان

مقياس الاحتمال والأثر من 1 إلى 5، درجة الخطر تساوي الاحتمال مضروباً في الأثر

الملاحظة	الأصل	الاحتمال	الأثر	درجة الخطر	المدة المستهدفة للمعالجة بالأيام	قرار التحسين	موعد إعادة الاختبار
الملاحظة 1: تفويض غير موحد	خدمة إدارة صلاحيات المستخدمين	4	5	20.00	9	إعادة بناء قرار التفويض في طبقة الخدمة الخلفية وربطه بمصفوفة الصلاحيات.	2026-04-08
الملاحظة 2: ترويسات حماية غير مكتملة	الخادم الوسيط للبوابة	3	3	9.00	18	توحيد إعداد الحماية ضمن إجراء تغيير معتمد ومراجع.	2026-04-20
الملاحظة 3: نسخ احتياطي وسجل استعادة	نسخ قاعدة البيانات التجريبية	3	4	12.00	16	تفعيل مسار نسخ مركزي مشفر واختبار الاستعادة الموثق.	2026-04-18
الملاحظة 4: غياب عامل إضافي للإدارة	حسابات مشرفي النظام	4	5	20.00	11	فرض المصادقة متعددة العوامل على الحسابات الإدارية ومراجعة الاستثناءات.	2026-04-10
متوسط درجة الخطر							15.25
أعلى درجة خطر							20.00

تستخدم الدرجة لترتيب العمل التعليمي ولا تغني عن تقدير مالك الأصل ومدير المخاطر للسياق التشغيلي الفعلي.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- تستخدم هذه المصفوفة درجات الخطر المحسوبة لترتيب المعالجة، لكنها لا تستبدل تحليل السياق.
- قارن بين الملاحظتين ذواتي الدرجة 20.0، ثم راجع الأصل المتأثر وقرار التحسين وموعد إعادة الاختبار.
- لاحظ أن الترويسات غير المكتملة درجتها 9.0 ومع ذلك تتطلب إجراء تغيير موحداً ومراجعاً قبل النشر.



نشاط إلزامي، ترتيب قرارات المعالجة



- ◀ الزمن: 14 دقيقة.
- ◀ استخدم درجات الخطر 20.0 و 9.0 و 12.0 و 20.0 للملاحظات الأربع.
- ◀ رتب الملاحظات من الأعلى إلى الأدنى، ثم اكتب مبرراً لكيفية التعامل مع التعادل بين الأولى والرابعة.
- ◀ يجب أن يشمل المبرر الأصل المتأثر وموعدتي إعادة الاختبار 2026-04-08 و 2026-04-10، لا الدرجة وحدها.
- ◀ **النتائج المطلوبة:** جدول ترتيب من أربعة صفوف ومبرر قرار من ثلاثة أسطر.

إجابة النشاط، ترتيب قرارات المعالجة

- ▶ تتقدم الملاحظتان 1 و 4 لأن درجة كل منهما 20.0، ثم الملاحظة 3 بدرجة 12.0، ثم الملاحظة 2 بدرجة 9.0. لا يحسم التعادل حسابياً.
- ▶ يوثق الفريق مقارنة خدمة إدارة الصلاحيات بحسابات مشرفي النظام، وقراري التحسين، وموعد إعادة الاختبار.
- ▶ يمكن بدء معالجة الملاحظة 1 قبل الرابعة لأن موعد تحققها 2026-04-08 أسبق.

الترتيب	الملاحظة	درجة الخطر	موعد إعادة الاختبار
1	تفويض غير موحد	20.0	2026-04-08
2	غياب عامل إضافي للإدارة	20.0	2026-04-10
3	نسخ احتياطي وسجل استعادة	12.0	2026-04-18
4	ترويسات حماية غير مكتملة	9.0	2026-04-20

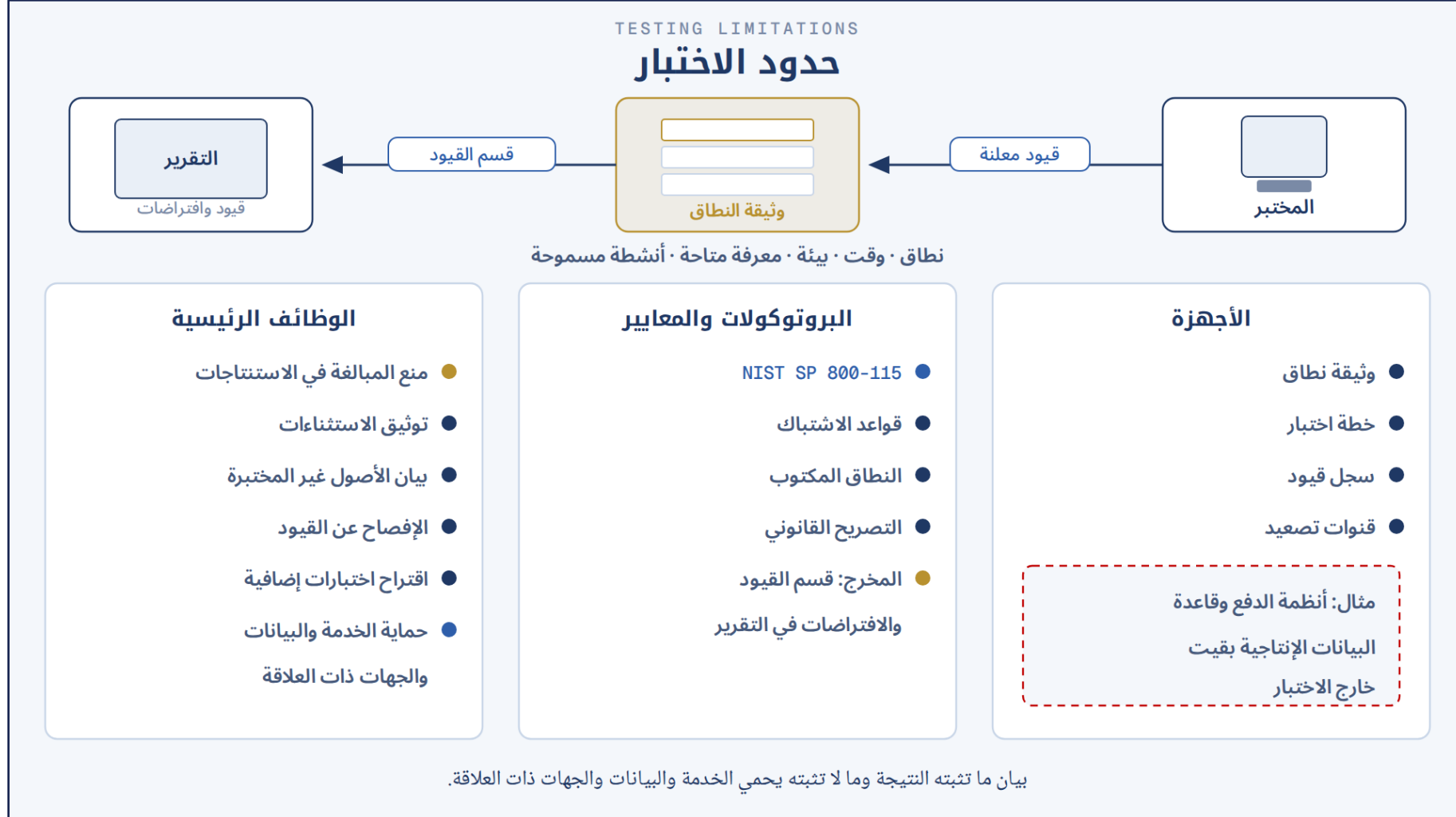


حدود الاختبار (Testing Limitations)

- ◀ حدود الاختبار قيود معلنة على النطاق والوقت والبيئة والمعرفة المتاحة والأنشطة المسموحة.
- ◀ وظيفتها بيان ما يمكن أن تثبته النتيجة وما لا تثبته، وحماية الخدمة والبيانات والجهات ذات العلاقة.
- ◀ **الوظيفة:** منع المبالغة في الاستنتاجات.
- ◀ **المسؤوليات:** توثيق الاستثناءات، بيان الأصول غير المختبرة، الإفصاح عن القيود، اقتراح اختبارات إضافية.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-115، قواعد الاشتباك، النطاق المكتوب، التصريح القانوني.
- ◀ **الأجهزة أو الأدوات:** وثيقة نطاق، خطة اختبار، سجل قيود، قنوات تصعيد.
- ◀ **المخرج:** قسم القيود والافتراضات في التقرير.
- ◀ **مثال:** يصرح التقرير بأن أنظمة الدفع وقاعدة البيانات الإنتاجية بقيت خارج الاختبار.



(الشكل) (Testing Limitations) حدود الاختبار

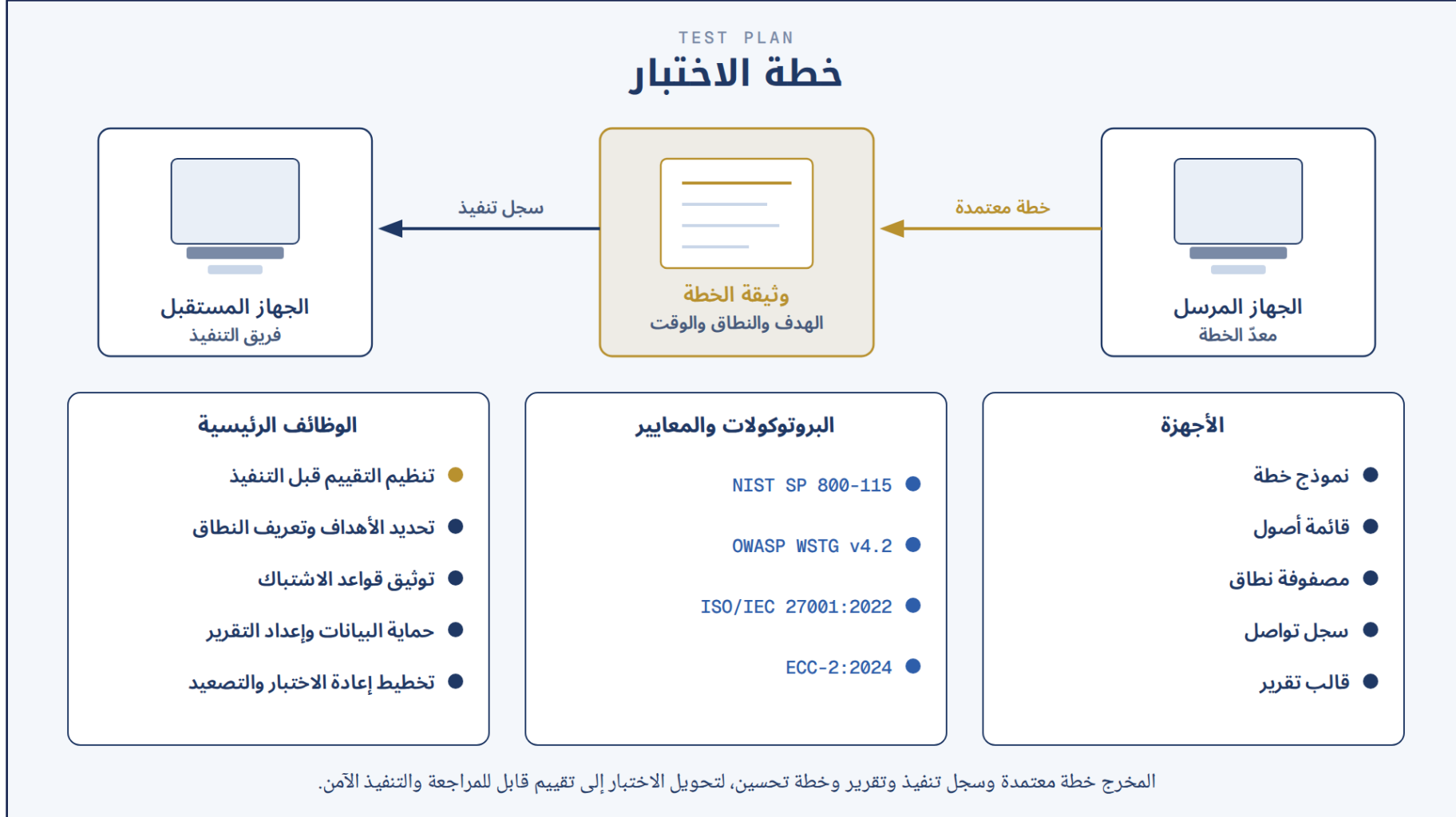




- ◀ خطة الاختبار وثيقة تنظم الهدف والنطاق والمنهجية والموارد والوقت والتصريح والتعامل مع النتائج والتصعيد.
- ◀ وظيفتها تحويل الاختبار من نشاط عشوائي إلى تقييم قابل للمراجعة والتنفيذ الآمن.
- ◀ **الوظيفة:** تنظيم التقييم قبل التنفيذ.
- ◀ **المسؤوليات:** تحديد الأهداف، تعريف النطاق، توثيق قواعد الاشتباك، حماية البيانات، إعداد التقرير، تخطيط إعادة الاختبار.
- ▶ **المعايير:** NIST SP 800-115, OWASP WSTG v4.2, ISO/IEC 27001:2022, ECC-2:2024.
- ◀ **الأجهزة أو الأدوات:** نموذج خطة، قائمة أصول، مصفوفة نطاق، سجل تواصل، قالب تقرير.
- ◀ **المخرج:** خطة معتمدة وسجل تنفيذ وتقرير وخطة تحسين.
- ◀ **مثال:** تحدد خطة البوابة التجريبية نافذة العمل من 20:15 الساعة 2026-03-22 إلى 2026-03-24 الساعة 23:35.



خطة الاختبار (Test Plan) (الشكل)





- ◀ الزمن: 13 دقيقة.
- ◀ اقرأ صف إدارة الاستثناءات في مصفوفة الامتثال.
- ◀ حدد نوع الفجوة، ثم اكتب إجراءً علاجياً يتضمن المالك والسبب ومدة الانتهاء والموافقة.
- ◀ صغ مؤشر فعالية واحداً قابلاً للتحقق، وحدد حالة إعادة الاختبار الواردة في المصفوفة.
- ◀ اشرح في سطرين لماذا لا تمثل النتيجة شهادة امتثال رسمية.
- ◀ **الناتج المطلوب:** بطاقة معالجة تتضمن الإجراء والمالك والمؤشر وموعد إعادة الاختبار.

- ◀ فجوة إدارة الاستثناءات تشغيلية وحالتها غير مطابقة.
- ◀ ينشئ العميل (منشأة سعودية) سجل استثناءات يثبت المالك والسبب ومدة الانتهاء والموافقة المعتمدة، ويراجعه دورياً.
- ◀ مؤشر الفعالية هو عدم وجود استثناء نشط بلا مالك أو تاريخ انتهاء أو موافقة موثقة.
- ◀ إعادة الاختبار مجدولة في 2026-04-24، والمصفوفة التعليمية لا تمنح شهادة امتثال.

العنصر	الإجابة
نوع الفجوة	تشغيل
الإجراء	سجل استثناءات ومراجعة دورية
مؤشر الفعالية	لا استثناء نشط بلا بيانات إلزامية
إعادة الاختبار	2026-04-24



✓ **قارنت** أساليب الصندوق الأسود والأبيض والرمادي بسؤال التصميم ومستوى المعرفة، تحقيقاً للهدف الثاني.

✓ **ميزت** بين الاختبار الوظيفي والاختبار الأمني واختبار الاختراق والمسح الآلي، تحقيقاً للهدف الأول.

✓ **رتبت** تحسينات التصميم وفق درجة الخطر والأصل وموعد إعادة الاختبار، تحقيقاً للهدف الرابع.

✓ **قيمت** فجوات التصميم والتشغيل بمصفوفة امتثال تعليمية، تحقيقاً للهدف الثالث.

✓ **ربطت** الاختبار بالنطاق المكتوب والتصريح والمسؤولية الأخلاقية في المملكة، تحقيقاً للهدف الخامس.



- ▶ Scarfone, K. A., Souppaya, M. P., Cody, A., & Orebaugh, A. D. (2008). Technical Guide to Information Security Testing and Assessment, NIST SP 800-115. يدعم التخطيط والتنفيذ وتحليل النتائج والمعالجة.
- ▶ OWASP Foundation. (دون تاريخ). OWASP Web Security Testing Guide, Version 4.2. يدعم اختبار الويب والمراجعة اليدوية والإبلاغ.
- ▶ International Organization for Standardization. (2022). ISO/IEC 27001:2022: Information Security Management Systems, Requirements, Edition 3. يدعم إدارة المخاطر والتحسين المستمر.
- ◀ الهيئة الوطنية للأمن السيبراني. (2024). الضوابط الأساسية للأمن السيبراني: ECC-2:2024. يدعم سياق الضوابط والالتزام السعودي.
- ◀ هيئة الخبراء بمجلس الوزراء. (1428هـ/2007م). نظام مكافحة جرائم المعلوماتية، مرسوم ملكي رقم م/17. يدعم التصريح والنطاق والمسؤولية.
- ▶ Anderson, R. (2020). Security Engineering: A Guide to Building Dependable Distributed Systems, الطبعة الثالثة. يدعم منظور هندسة الأمن، والتحسين.
- ▶ Johnsson, D. B., Deogun, D., & Sawano, D. (2019). Secure by Design. Manning Publications. يدعم دمج الأمن في دورة البناء والاختبار والنشر.
- ◀ التعليل: تتكامل المراجع بين منهجية التقييم، واختبار الويب، وإدارة الضوابط، والسياق السعودي، وتحسين التصميم.



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شكراً لكم

معهد البحوث والخدمات الاستشارية – جامعة جازان